© SANS Institute 2025

549.5

Enabling the Cloud-Focused SOC

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

© 2025 SANS Institute. All rights reserved to SANS Institute.

PLEASE READ THE TERMS AND CONDITIONS OF THIS COURSEWARE LICENSE AGREEMENT ("CLA") CAREFULLY BEFORE USING ANY OF THE COURSEWARE (DEFINED BELOW) ASSOCIATED WITH THE SANS INSTITUTE COURSE. THIS IS A LEGAL AND ENFORCEABLE CONTRACT BETWEEN YOU (THE "USER") AND THE ESCAL INSTITUTE OF ADVANCED TECHNOLOGIES, INC. /DBA SANS INSTITUTE ("SANS INSTITUTE") FOR THE COURSEWARE. BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA.

With this CLA, SANS Institute hereby grants User a personal, non-exclusive license to use the Courseware subject to the terms of this CLA. Courseware means all printed materials, including course books and lab workbooks, slides or notes, as well as any digital or other media, audio and video recordings, virtual machines, software, technology, or data sets distributed by SANS Institute to User for use in the SANS Institute course associated with the Courseware. User agrees that the CLA is the complete and exclusive statement of agreement between SANS Institute and User and that this CLA supersedes any oral or written proposal, agreement or other communication relating to the subject matter of this CLA.

BY ACCESSING THE COURSEWARE, USER AGREES TO BE BOUND BY THE TERMS OF THIS CLA. USER FURTHER AGREES THAT ANY BREACH OF THE TERMS OF THIS CLA MAY CAUSE IRREPARABLE HARM AND SIGNIFICANT INJURY TO SANS INSTITUTE, AND THAT SANS INSTITUTE MAY ENFORCE THESE PROVISIONS BY INJUNCTION (WITHOUT THE NECESSITY OF POSTING BOND), SPECIFIC PERFORMANCE, OR OTHER EQUITABLE RELIEF.

If User does not agree to the terms of this CLA, User should not access the Courseware. User may return the Courseware to SANS Institute for a refund, if applicable.

User may not copy, reproduce, re-publish, distribute, display, modify or create derivative works based upon all or any portion of the Courseware, in any medium, whether printed, electronic or otherwise, for any purpose, without the express prior written consent of SANS Institute. User may not sell, rent, lease, trade, share, or otherwise transfer the Courseware in any way, shape, or form to any person or entity without the express written consent of SANS Institute. Additionally, User may not upload, submit, or otherwise transmit Courseware to any artificial intelligence system, platform, or service for any purpose, regardless of whether the intended use is commercial, educational, or personal, without the express written consent of SANS Institute. User agrees that the failure to abide by this provision would cause irreparable harm to SANS Institute that is impossible to quantify. User therefore agrees to a base liquidated damages amount of $5000.00 USD per item of Courseware infringed upon or fraction thereof. In addition, the base liquidated damages amount shall be doubled for any Courseware less than a year old as a reasonable estimation of the anticipated or actual harm caused by User's breach of the CLA. Both parties acknowledge and agree that the stipulated amount of liquidated damages is not intended as a penalty, but as a reasonable estimate of damages suffered by SANS Institute due to User's breach of the CLA.

If any provision of this CLA is declared unenforceable in any jurisdiction, then such provision shall be deemed to be severable from this CLA and shall not affect the remainder thereof. A written amendment or addendum to this CLA that is executed by SANS Institute and User may accompany this Courseware.

SANS Institute may suspend and/or terminate User's access to and require immediate return of any Courseware in connection with any (i) material breaches or material violation of this CLA or general terms and conditions of use agreed to by User, (ii) technical or security issues or problems caused by User that materially impact the business operations of SANS Institute or other SANS Institute customers, or (iii) requests by law enforcement or government agencies.

SANS Institute acknowledges that any and all software and/or tools, graphics, images, tables, charts or graphs presented in this Courseware are the sole property of their respective trademark/registered/copyright owners, including:

The Apple® logo and any names of Apple products displayed or discussed in this book are registered trademarks of Apple, Inc.

PMP® and PMBOK® are registered trademarks of PMI.

SOF-ELK® is a registered trademark of Lewes Technology Consulting, LLC. Used with permission.

SIFT® is a registered trademark of Harbingers, LLC. Used with permission.

VMware Workstation Pro®, VMWare Workstation Player®, VMWare Fusion®, and VMware Fusion Pro® are registered trademarks of VMware, Inc. Used with permission.

Governing Law: This CLA shall be governed by the laws of the State of Maryland, USA.

Courseware licensed to User under this CLA may be subject to export laws and regulations of the United States of America and other jurisdictions. User warrants he or she is not listed (i) on any sanction programs list maintained by the U.S. Office of Foreign Assets Control within the U.S. Treasury Department ("OFAC"), or (ii) denied party list maintained by the U.S. Bureau of Industry and Security within the U.S. Department of Commerce ("BIS"). User agrees to not allow access to any Courseware to any person or entity in a U.S. embargoed country or in violation of a U.S. export control law or regulation. User agrees to cooperate with SANS Institute as necessary for SANS Institute to comply with export requirements and recordkeeping required by OFAC, BIS or other governmental agency.

All reference links are operational in the browser-based delivery of the electronic workbook.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

SANS | CLOUD SECURITY

SEC549.5

Enabling the Cloud-Focused SOC

CLOUD SECURITY ARCHITECTURE

© 2025 SANS INSTITUTE | ALL RIGHTS RESERVED

K01_01

This section covers how to enable your SOC to operate (investigate incidents, retrieve log events, hunt for threats) in the new cloud-based world.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Table of Contents

Incident Response in the Cloud	3
Lab 5.1: Threat Model: Managing Cloud-Native Events	17
Intra-Cloud Logging and Aggregation	19
Lab 5.2: SAR: Centralizing Cloud-Native Events	56
Centralization and Export Patterns	58
Lab 5.3: SAR: Exporting Telemetry to a SIEM – Azure	72
Lab 5.4: SAR: Exporting Telemetry to a SIEM – AWS	80
Lab 5.5: SAR: Exporting Telemetry to a SIEM – GCP	87
Course Wrap-Up	89
Lab 5.6: CloudWars: Incident Response and Final Presentation	95
Additional Resources	96
Contacts and Resources	101

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Course Roadmap

Section 1: Cloud Account Management and Identity Foundations

Section 2: Implementing an Identity Perimeter in the Cloud

Section 3: Network Access Perimeters for the Cloud

Section 4: Data Access Perimeters in the Cloud

Section 5: Enabling the Cloud-Focused SOC

- Incident Response in the Cloud
  - Lab 5.1: Threat Model: Managing Cloud-Native Events
- Intra-Cloud Logging and Aggregation
  - Lab 5.2: SAR: Centralizing Cloud-Native Events
- Centralization and Export Patterns
  - Lab 5.3 SAR: Exporting Telemetry to a SIEM – Azure
  - Lab 5.4 SAR: Exporting Telemetry to a SIEM – AWS
  - Lab 5.5 SAR: Exporting Telemetry to a SIEM – GCP
- Course Wrap-Up
  - Lab 5.6: CloudWars: Incident Response and Final Presentation
- Additional Resources

It's inevitable that even the most mature, cloud-native organizations will have their security posture challenged. This is why the phrase from Dr. Eric Cole, "Prevention is ideal, but detection is a must,"[1] rings so true. All organizations must prepare for an inevitable incident and be in a position to respond when it occurs. But often, traditional security operational centers (SOCs) are not tuned to respond in a cloud environment.

To pave a path for a cloud-focused SOC, a partnership is required between security architecture and SOC practitioners. In this section, we focus on how to uplift a SOC's capabilities and adapt traditional methodologies to cloud-hosted environments, ensuring robust detection and response continues as an organization shifts its workloads to the cloud.

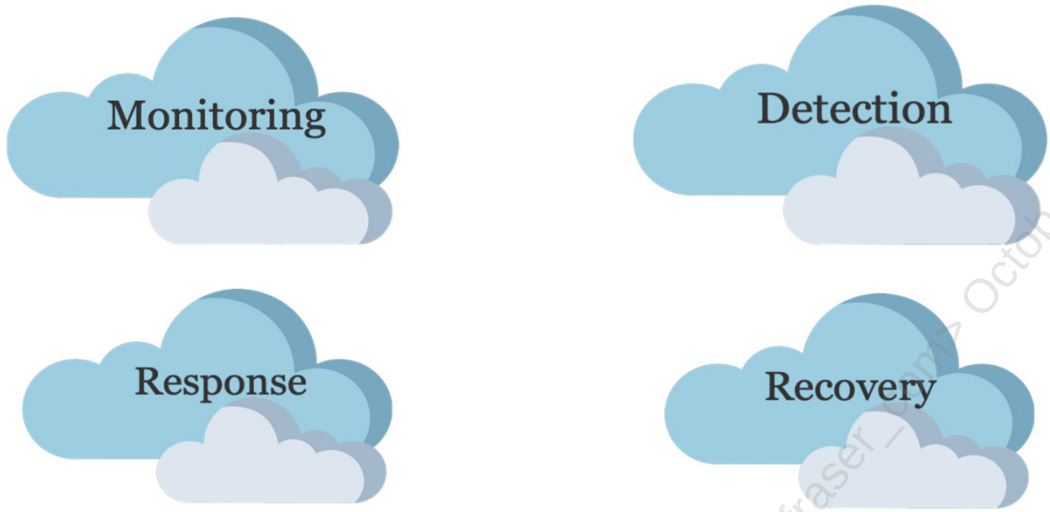
1. https://sec549.com/id467

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Security Operations in a Cloud-Centric World



Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

The goal of the security operations center (SOC) is to maintain monitoring across the attack surface, detect and respond to incidents, and recover when an event occurs. How do these actives need to be repositioned when targeting a cloud environment?

The Cloud-Focused SOC

As an organization matures, its security capabilities must evolve to keep pace with business growth and expansion. This often means shifting focus to unfamiliar territories such as the cloud. In a cloud-focused SOC, the core fundamentals do not change; rather, how their goals are achieved can vary substantially from a traditional network perimeter.

This section touches on the four pillars of a modern SOC and how the move to the cloud necessitates a shift in tooling and approach. In each of the following categories, we will outline how security architecture empowers the SOC, setting them up for success as they respond to threats, proactively hunt for attacks, and help the business recover from an incident in the cloud.

Monitoring: Many new sensors and telemetry types are available in the cloud, especially for non-IaaS workloads (PaaS, FaaS, and SaaS). It's important that your responders have access to the new breadth of data points available in the cloud.

Detection: The incident information collection effort for non-IaaS workloads using traditional detection methodologies can be either meaningless or impossible.

Response: If you see something bad, what are you going to do about it? How do you execute your cloud runbook?

Recovery: The cloud often provides a lot more flexibility in recovery, especially for IaaS. When infrastructure is codified as code (infrastructure-as-code), it allows you to quickly rebuild to a known good state.

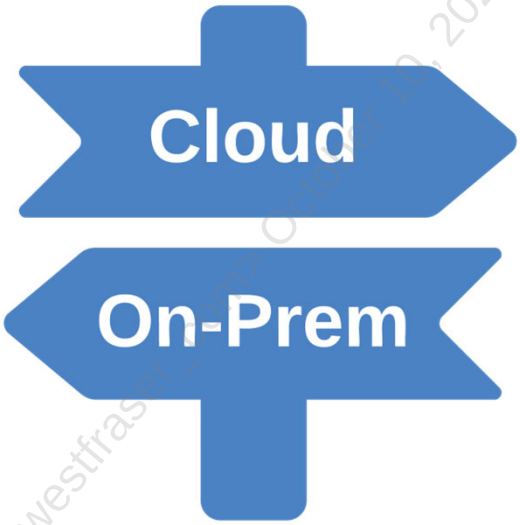
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Operations in Cloud vs. On-Premises: Similarities

Most concepts from a traditionally-focused SOC continue forward into the cloud.

- High-fidelity detections with supporting data are required by analysts.
- Existing methodologies used for on-premises will likely be very similar for IaaS.
- Automating detection triage and remediation is still critical for democratizing the SOC workload.



A majority of foundational concepts underpinning traditional SOCs carry forward into the cloud.[1]

A mature SOC will have these concepts built into their monitoring, detection, and response program:

- Analysts still need to understand the resources they are defending. Without a base understanding of the rules of the road, an analyst is likely to be lost when investigating cloud incidents.
- Analysts need both adequate log coverage and high-fidelity detections to do their jobs.
- Existing playbooks are likely to work for IaaS (i.e., EC2, Compute, VMs).
- Network-layer visibility from resources like firewalls is likely to provide similar telemetry as on-prem counterparts.
- Automation around detection, triage, and remediation is still critical for democratizing the SOC workload.

1. https://sec549.com/id233

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Operations in Cloud vs. On-Premises: Differences

- New logging planes emerge as critical sources for telemetry.
- Monitoring non-IaaS resources in the cloud will look substantially different than on-prem.
- Attacker activity in the cloud is unlikely to be captured by any network-layer inspection.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

While the foundations underpinning a successful security operations center do not radically change when workloads move to the cloud, the realities on the ground mean their tactical implementations need to keep pace with the new landscape.

Reassessing the core concepts of a mature SOC through the lens of a cloud-centric business, we can see how differences emerge.

- Analysts still need to understand the resources they are defending.
  - Upskilling SOC analysts should be a priority to ensure an organization maintains parity with its on-premises monitoring and response capabilities.
- Analysts need both adequate log coverage and high-fidelity detections to do their jobs.
  - New logging planes emerge as critical sources for telemetry, while classic host-based and network-layer logging is either non-existent or significantly less important when investigating.
- Existing playbooks are likely to work for IaaS (i.e., EC2, Compute, VMs).
  - A high degree of domain knowledge is needed to effectively develop response and containment playbooks for PaaS, FaaS, and SaaS resources.
  - Monitoring these resources in the cloud will look substantially different than on-prem.
- Network-layer visibility from resources like firewalls is likely to provider similar telemetry as on-prem counterparts.
  - Attacker activity in the cloud is unlikely to be captured by any network-layer inspection.

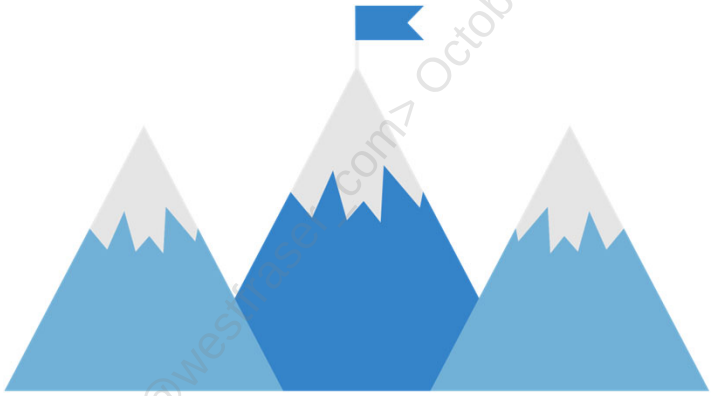
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Challenges for a Cloud-Focused SOC

- The duration of a campaign from initial compromise followed by actions on objectives can occur **much faster and easier** than on-prem.

- This shallow attack path necessitates:
  - **Comprehensive logging**
  - **High-fidelity detections**
  - **Automated response**



Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

What specifically makes the cloud so challenging for a traditional SOC and why are emerging threats elusive?

- The ephemeral nature of resources will challenge their ability to instrument and write good detections.
- The sheer volume of resources can increase faster than a SOC can keep up, and will typically grow larger than on-prem.
- Similar to Shadow IT, Shadow Cloud Accounts can be easily created by business units that lack adequate logging, monitoring, and response abilities.
- When all capabilities of a system are exposed via a public API, the duration of a campaign from initial compromise, followed by actions on objectives, can occur much faster and easier than on-prem.
  - This shallow attack path necessitates high-fidelity detections and automated responses.

Reference:

- Image: Jumpsoft Toolbox for Keynote

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cloud-Native Tooling in the SOC

- Should the SOC leverage the cloud to support operations?
- Consider the following when determining if a cloud-based tool is more advantageous than one deployed on-premises:
  - Cost implications
  - Increased "speed to market"
  - Perceived or real risk affecting availability and confidentiality

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Can moving to the cloud help a SOC meet the upcoming challenges facing them in the cloud?

Business units are not the only teams migrating to the cloud. Security operations teams are also considering whether moving their processes to the cloud can bring productivity gains and cost savings.

Decision makers will juggle three primary factors when considering moving a given solution or tool to the cloud.

- **Cost**: How much more or less will a cloud-based SIEM cost over time versus a traditional on-premises solution?
- **Speed to Market**: Can an organization leapfrog any growing pains and achieve maturity faster with a managed, cloud-native solution?
- **Perceived Risk**: To what extent a cloud-based security solution can be secure greatly depends on the maturity of the organization. If a business is new in its cloud journey, only just beginning to enact controls in its cloud environments, a cloud-native security solution might not be the best choice. This is truer when a cloud-native solution is self-managed rather than a SaaS (software as a service) delivery model.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

CSP Coordination: Across Service Delivery Models

Detection and response responsibilities shift between the consumer and the cloud service provider depending on the service delivery model.

Responsibility	On-Prem	IaaS	PaaS	SaaS
Data classification & accountability risks	●	●	●	◐
Client & endpoint risks	●	●	●	●●
Identify & access risks	●	●	●●	●●
Application risks	●	●	●●	●
Network risks	●	●●	●	●
Host risks	●	●●	●	●
Infrastructure risks	●	●	●	●

Requires Internal Trust

Requires External Trust

● Cloud Provider is responsible ● Cloud Customer is responsible

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Incident response in the cloud is a shared responsibility between the cloud provider and its customers. Understanding where the boundaries of that line are is needed to effectively marshal resources to defend cloud resources. Let's look at what telemetry sources are available to the cloud consumer in each model, along with who is responsible for detection and response.

Shared Incident Response: Infrastructure as a Service (IaaS)
Offloaded to the CSP is the need to monitor for and detect risks in the physical data center. Managing operating system layer risks is still in scope for the customer when deploying on IaaS platforms such are AWS EC2 instances, Azure VMs, or GCP Compute Instances while the CSP manages the security of the hosts, including the detection and response capacity.

Shared Incident Response: Platform as a Service (PaaS)
Sensors at the operating system layer, in addition to the host, are deployed, configured, and monitored by the CSP in all platform as a service models. The customer should focus on detecting and responding to threats at the application layer when customer control code is deployed such as in serverless models (for example, AWS Lambda, GCP Cloud, and Azure Functions or GCP Cloud Run). Information collection often extends to Layer 7 network traffic when utilizing managed web application firewalls (WAFs) and API gateways.

Shared Incident Response: Software as a service (SaaS)
As with all cloud service delivery models, the cloud consumer must focus on anomalies at the cloud control plane. When using a SaaS service, often events from the cloud control plane are the only source of telemetry for investigating an event. The cloud consumer cannot access OS-layer or application-layer telemetry. Only by focusing on the abuse of cloud resources (including identity resources) via the cloud provider's API can a SOC identity threats and prefer root cause analysis.

Reference:

- Image: https://sec549.com/id234

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

CSP Coordination: CSP Communication of Incidents

Security Advisory Bulletins

- Ad hoc security-related communiques issued by CSPs when novel vulnerabilities are released.
- Security bulletins may or may not require customers to take action including upgrading software versions or re-building containers.

Abuse Reports

- Communications from your CSP when they identify cloud resource abuse originating from your environment.
- Direct engagement from the CSP if resources in your cloud account are hijacked and leveraged in a variety of abuse campaigns.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

The Shared Responsibility Model isn't always an impervious wall separating the customer and the CSP. Especially in the realm of security incidents, coordination and communication are required between the two parties. Here is where you can expect your CSP to coordinate, communicate, or assist in an incident investigation.

Security Bulletins

AWS,[1] GCP,[2] and the Microsoft Security Response Center[3] (MSRC) will all issue security bulletins in response to threats affecting both the customers' side and the providers' side of the shared responsibility model. These bulletins serve to communicate the impact (if any) to cloud customers when new vulnerabilities are released. Action may or may not be required by the cloud consumer. For example, a security advisory for OpenSSL v3 (CVE-2022-3602 and CVE-2022-3786) was issued by AWS on November 1 of 2022,[4] where impact to AWS platform infrastructure is addressed, and outlined are the scenarios in which AWS customers need to update and patch their cloud-hosted operating systems and container instances.

Abuse Reports

Customer trust and safety of the cloud platform are a paramount concern for a CSP. As such, abuse reports of cloud resources are distributed to impacted customers. Perhaps cloud resources are leveraged in a Botnet campaign,[5] or the CSP identifies command and control (C&C) servers being hosted on their infrastructure. In any case, if resources in your cloud account are reported as being a part of an attack, expect direct communication from your CSP with details of the activity they observed. Failure to respond to an abuse report and address its root cause often results in the blocking or suspending of your resources.

Types of abuse commonly identified and triaged by a CSP Trust and Safety Team include:

- Spam: Cloud resources were utilized in spam campaigns.
- Port scanning: Network-layer logs revealed cloud-hosted servers being used to identify open ports.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

- Denial-of-service (DoS) attacks: Network-layer logs revealed cloud-hosted servers being used to flood ports in an attempt to crash systems.
- Intrusion attempts: Logging showed multiple attempts to log in to resources.
- Hosting prohibited content: Illegal content or copyrighted content was found to be hosted on cloud infrastructure.
- Distributing malware: Cloud infrastructure was used to distribute malware.

1. https://sec549.com/id210
2. https://sec549.com/id211
3. https://sec549.com/di212
4. https://sec549.com/id213
5. https://sec549.com/id214

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

CSP Coordination: Securing Communication Channels

- **Configuring and Securing Communication Channels**
  - Is the security contact a distribution list or an individual's email address?
  - Who is monitoring the inbox where abuse reports are sent?
  - Is the inbox monitored for suspicious email forwarding rules?

- **Enhancing Visibility**
  - Are CSP Security Bulletins published in a well known, frequently accessed location?
  - Ensure the SOC knows where to find where AWS Security Bulletins are published.
  - Consider posting RSS feeds from the CSP to a dedicated Teams or Slack channel.

Architecting a secure cloud environment doesn't stop at implementing best practice network or identity architectures. As architects, we are responsible for designing secure processes on the use of cloud, such as ensuring the correct stakeholders are made aware when security incidents arise.

Establishing well-known communication channels through distribution lists is an often overlooked but critical piece in any partnership with a cloud service provider (CSP). As opposed to an individual's inbox, a distribution list is preferable, as it removes the dependency away from a single person who may be negligent, away from the office, or an insider threat.

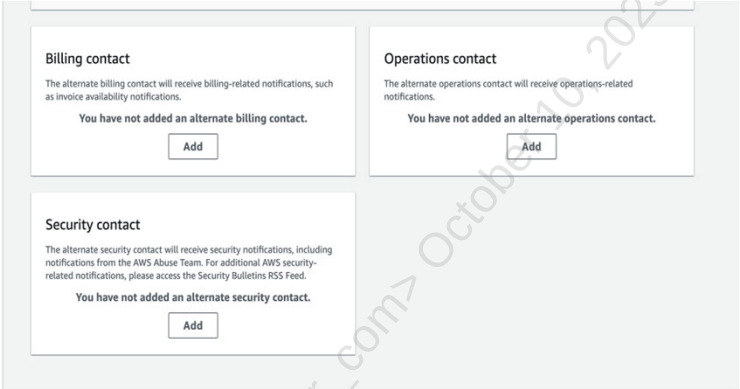
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

CSP Coordination: AWS Alternate Security Contacts

- **AWS**
  - Update your alternate security contacts per AWS account to receive timely notifications of security incidents and reports of abuse.
- **AWS Organizations**
  - Leverage Organizations from the management account to update the alternate security contact programmatically for all member accounts.



Within a single account, you can configure additional alternate contacts for communications from AWS related to billing, operations, and security. Without adding additional alternate contacts, all communications from AWS, whether they relate to billing, outages, or time-sensitive abuse reports, are sent to the root email address, which is unlikely to be monitored rigorously.

The security alternate contact will receive notifications from AWS Security, the Abuse Team, and the Trust and Safety Team. These communications could include environment-specific correspondence, such as notifying account holders if there are indicators of hijacked resources in the environment.

Every AWS account requires its own security contact to be defined, as notifications are sent on a per-account basis. A security contact is not inherited from a setting from, say, the management account. However, with AWS Organizations, setting the security alternate contact for all member accounts can be performed in bulk and programmatically, making the task less arduous.[1]

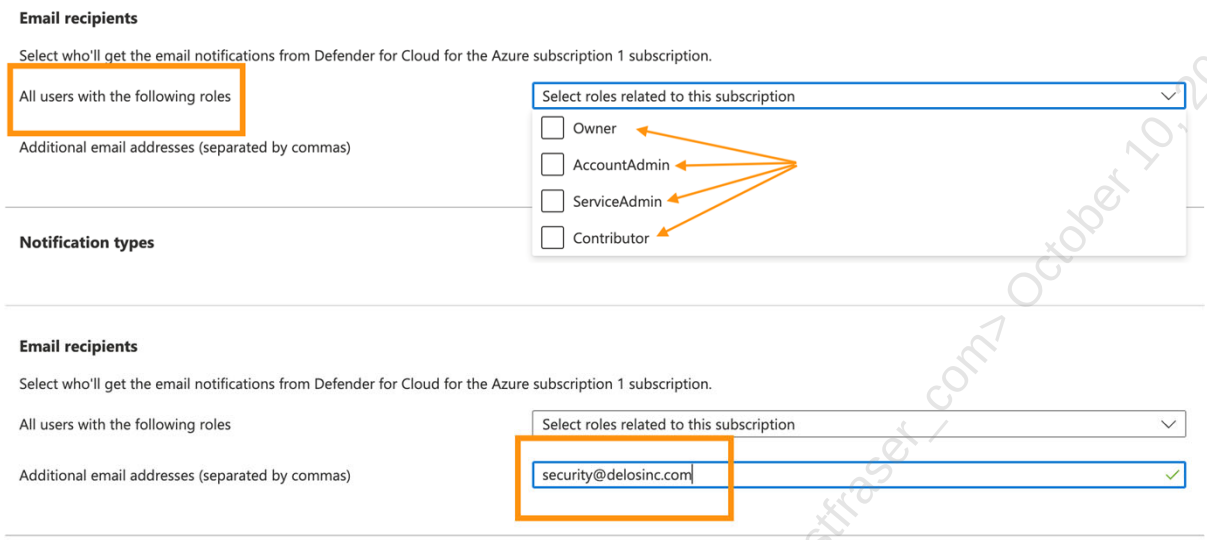
1. https://sec549.com/id235

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

CSP Coordination: Defender for Cloud Security Contacts



By default, Azure only notifies the subscription owner with security alerts. There are two methods to expand who the Defender for Cloud notifies and ensure your SOC's distribution list is included.

1. In the Defender for Cloud settings for every subscription, enable security notifications for principals holding either the owner, accountadmin, serviceadmin, or contributor roles.
2. Add ad hoc contacts to the "Additional email addresses" field. This is the best strategy for adding the appropriate stakeholders to security alerts.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

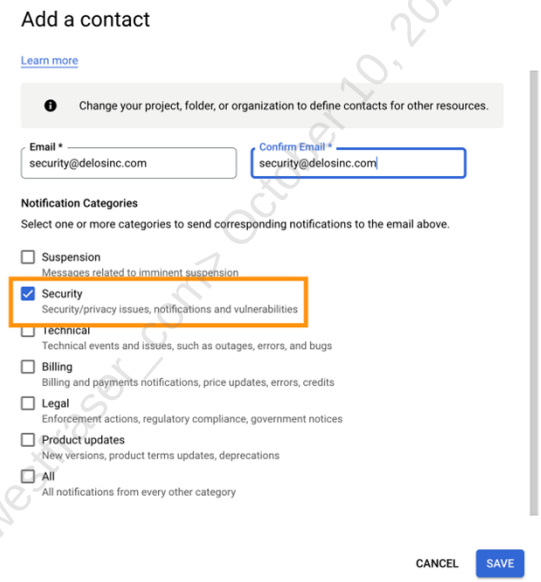
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

CSP Coordination: GCP Essential Contacts

- Enforce guardrails with Org Policy Constraints for Essential Contacts

Essential Contacts	Domain restricted contacts	This list constraint defines the set of domains that email addresses added to Essential Contacts can have. By default, email addresses with any domain can be added to Essential Contacts. The allowed/denied list must specify one or more domains of the form `@example.com`. If this constraint is active and configured with allowed values, only email addresses with a suffix matching one of the entries from the list of allowed domains can be added in Essential Contacts. This constraint has no effect on updating or removing existing contacts. `constraints/essentialcontacts.allowedContactDomains`	`"is:`
Essential Contacts	Disable Project Security Contacts	This boolean constraint, when enforced, allows organization policy administrators to ensure that only contacts assigned at the organization or folder level can receive security notifications. Specifically, enforcing this constraint blocks project owners and contact administrators from creating or updating an Essential Contact with a `notification_category_subscriptions` field that contains either the `SECURITY` or `ALL` category, if the contact also has a project resource as a parent. `constraints/essentialcontacts.disableProjectSecurityContacts`	`"is:`



Essential Contacts[1] is a service from Google Cloud that allows its customers to set contacts for various notification categories such as billing, legal, and security. Notification categories can have multiple contacts configured. Like all resources in Google Cloud, Essential Contacts abides by the organization's hierarchy structure. A contact set at the organization, folder, or project level will receive notifications within that scope.

Google Cloud offers its customers a couple Org Policy Constraints[2] related to the Essential Contacts service to help place guardrails on the use and possible abuse of this service. By implementing these Org Policy Constraints, you can prevent notifications from being redirected or eavesdropped on.

- **contraints/essentialcontacts.allowedContactDomains**
  - An allowable list of domains for which email addresses can be added as Essential Contacts.
- **contraints/essentialcontacts.disableProjectSecurityContacts**
  - A Boolean value that disables the ability to set the security contact at the project level. Instead, a security contact can only be inherited from its folder or organizational parent.

1. https://sec549.com/id236
2. https://sec549.com/id237

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

CSP Coordination: Managed Services from the CSPs

"The team we hope you never meet"

- AWS Customer Incident Response Team: **AWS CIRT**
- Google Cybersecurity Action Team: **GCAT**
- Azure Detection and Response Team: **DART**

Investigations of cloud incidents that occur squarely on the customer side of the shared responsibility model, at times, can benefit from support from your CSP.

To augment any internal cloud domain knowledge, specialized response teams from your CSP can be contracted during any phase of an incident. Their services can be obtained to support the incident response lifecycle at any phase: preparation, detection and analysis, containment, and recovery or post-mortem.

References:

- DART: the Microsoft cybersecurity team we hope you never meet
  https://sec549.com/id238
- NIST Computer Security Incident Handling Guide
  https://sec549.com/id209
- AWS Customer Incident Response Team
  https://sec549.com/id240
- Google Cybersecurity Action Team
  https://sec549.com/id241
- Microsoft Incident Response (formerly DART/CRSP)
  https://sec549.com/id242

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

SANS | CLOUD SECURITY

Lab 5.1

Threat Model: Managing Cloud-Native Events

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Lab 5.1: Summary

In this lab, you:

- Reviewed the current state of event configuration for the Delos cloud environment
- Considered threats that might be of concern for the cloud environment
- Explored options for how to address the threats considered during the threat model exercise

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Course Roadmap

Section 1: Cloud Account Management and Identity Foundations

Section 2: Implementing an Identity Perimeter in the Cloud

Section 3: Network Access Perimeters for the Cloud

Section 4: Data Access Perimeters in the Cloud

Section 5: Enabling the Cloud-Focused SOC

- Incident Response in the Cloud
  - Lab 5.1: Threat Model: Managing Cloud-Native Events
- Intra-Cloud Logging and Aggregation
  - Lab 5.2: SAR: Centralizing Cloud-Native Events
- Centralization and Export Patterns
  - Lab 5.3 SAR: Exporting Telemetry to a SIEM – Azure
  - Lab 5.4 SAR: Exporting Telemetry to a SIEM – AWS
  - Lab 5.5 SAR: Exporting Telemetry to a SIEM – GCP
- Course Wrap-Up
  - Lab 5.6: CloudWars: Incident Response and Final Presentation
- Additional Resources

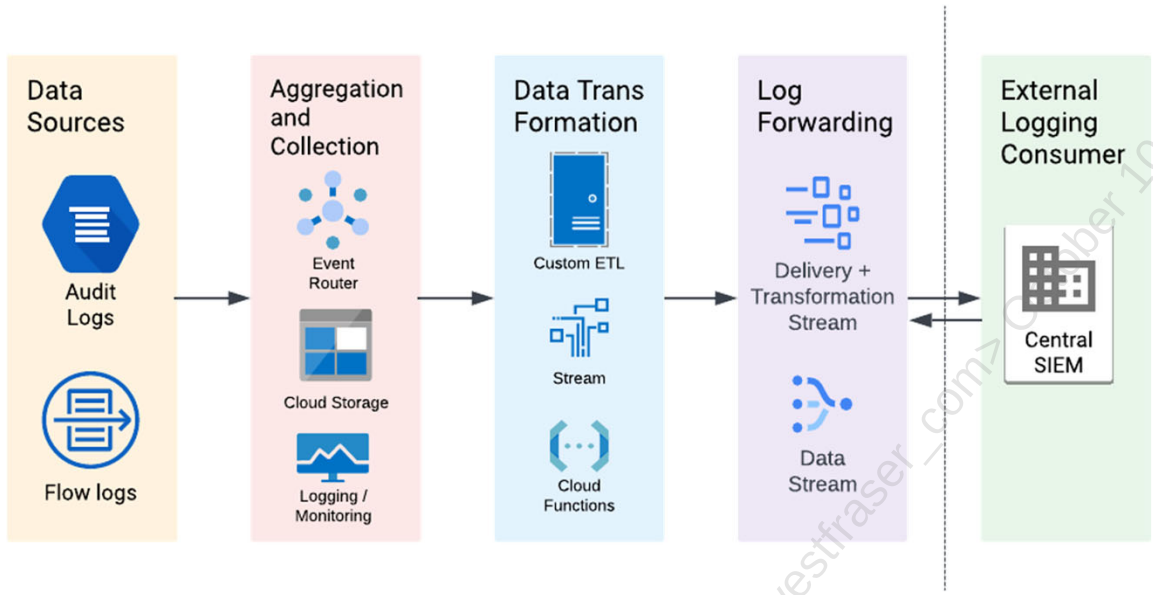
This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Monitoring Journey Overview: Data Source to SIEM



During the next two modules, you will follow the path of a cloud event from the moment it is generated to its collection, aggregation within the cloud environment, and ultimate forwarding to a central logging solution. This will give you a better understanding of how cloud logs are processed and how they are used to support investigations.

Data sources for cloud environments can include any log, metric, or insight collected by built-in cloud-native logging or third-party solutions. These sources can be spread across many accounts and be stored in various locations, making it difficult to access and analyze all of the available data.

The aggregation of cloud data sources refers to the process of collecting and combining data from various sources within a cloud environment. This can include data from built-in cloud-native logging solutions, third-party tools, and other sources. The aggregated data is often stored in a central location for easier access and analysis. The purpose of aggregation is to provide a comprehensive view of the data and make it easier to identify trends and patterns.

While this course doesn't dive deep into data transformation, note there are various tools that can be used for log data transformation in the cloud, including cloud-native solutions, custom scripts, and third-party ETL platforms. It's worth noting that the right tool for log data transformation will depend on the specific requirements of your environment and the resources you have available.

In this course, you will learn about cloud-native solutions that can be used to create both push and pull patterns for log data. The specific pattern that you choose (push or pull) will depend on the requirements of the logging solution or security information and event management (SIEM) system that you are using. This course provides in-depth coverage of these solutions to help you understand how to effectively use them in your environment.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cloud Monitoring Event Routing and Storage

Event Router	Log	SIEM	Data Lake
• Receives events and delivers them to zero or more destinations typically using a publish/subscribe model • Cloud service event routers provide near real-time visibility and response to events • Examples: Azure Event Grid, AWS EventBridge, & GCP Eventarc	• Storage and retention of events • Supports cloud control-plane, service, OS, application, and custom events • Examples: AWS CloudTrail / S3 / CloudWatch Log Groups, Azure Activity Logs / Azure Monitor Log Analytics, GCP Audit Logs / Cloud Logging	• Storage, retention, and correlation of events • Primarily used to detect and respond to security threats • Examples: GCP Chronicle, Microsoft Sentinel, Splunk Enterprise Security, Elastic Security, Security Onion	• In the context of monitoring, a centralized repository that stores, processes, and secures large amounts of de-normalized event data • Examples: Amazon CloudTrail Data Lake / Security Lake, Azure Data Explorer, GCP Big Query • Alternatively, cloud object storage services can be used

One key advantage of the cloud vs. on-premises environments is that the cloud providers offer services that give you a single place to view and respond to events that are happening in near real-time. These event router services, like Azure's Event Grid, Amazon's EventBridge, and Google's Eventarc, can be used for alerting and responding to identified threats in the environment. While correlation with other events is more difficult, if there are certain events that should be alerted on or responded to quickly and the message or response is consistent each time this event occurs, these event router services are ideal solutions.

While alerting and responding in near real time is extremely valuable, alert fatigue is real, and not all events will have a consistent enough response pattern to support automation. For this reason, the cloud providers offer logging solutions for storing and retaining logs. These built-in logging capabilities are essential for responders to help them investigate the alerts they are getting and to correlate with other events in the environment. Unfortunately, the default logging and monitoring capabilities in the cloud are not always security-focused, and some of them are harder or more expensive or slower to query, especially for larger data sets. This is where security incident and event management (SIEM) capabilities and data lakes play an important role.

With security incident and event management systems, the focus should be on security and automated correlation of events to help incident response teams to more quickly and accurately respond the threats in the environments they are responsible for monitoring. While these products are much better at focusing on security and may include pre-built rules and correlations, these capabilities come at a cost. Also, historically, these products have not been as high-performing as some of the other big data solutions. While there are some newer products and versions that tap into these big data capabilities, only time will tell if they measure up to the more established vendors in providing actionable alerts and response capabilities.

To optimize the SIEM and reduce costs, some organizations will transfer data to other storage after a certain number of days. For example, in Microsoft Sentinel, the data is only retained in primary storage

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

for a configurable number of days (90 days included, except Basic logs, which are 8 days). Then, customers can extend the primary storage retention, at a cost, or archive the data to other storage and age it out based on data retention policies.

The problem with archiving the logs from your SIEM is that the archive storage is typically harder or more expensive to query. In some cases, it may even need to be restored to primary storage. For this reason and possibly to reduce the amount of data even sent to the SIEM in the first place, some companies will also send their log data to a data lake. The big data products used for these data lakes will make querying the log data faster and may lower the cost of longer-term storage. They also provide a location for non-security resources to be granted access to data. This doesn't replace the need for a SIEM as the security-specific correlation and event management capabilities would need to be built custom for most of these solutions, but most of these correlation and event management capabilities are built to look at current data and so won't be looking at the older data anyway. The only downside is that your analysts will need access to more than one data set and potentially need to learn multiple query languages for investigations.

Object storage is a popular option for archiving logs from the primary storage and analysis mechanisms. Just because these logs are archived to objects doesn't necessarily mean they are not accessible for analysis. Amazon provides Athena for querying S3, Azure Blob Storage has an Azure Data Lake Storage Gen2 offering, and Google Cloud supports CloudStorage BigLake Tables. However, these are added services that turn these storage services into data lakes so count on costs increasing quite a bit when using these services.

Reference:

- https://learn.microsoft.com/en-us/azure/sentinel/billing?tabs=simplified%2Ccommitment-tiers#data-retention-and-archived-logs-costs

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Log Types Found in the Cloud

- Cloud control-plane logs
- Network-layer logs
- Platform/OS-layer logs
- Application-layer logs

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Covered in this section is a deep dive on cloud data sources, along with the aggregation of cloud logs and events within the cloud service provider (CSP).

Let's review the available sensors in cloud deployments and the visibility they can provide responders during an incident. Though some of the below detailed telemetry types will be familiar to those more accustomed to on-premises infrastructure, other logs, such as control-plane logs, are new and unique to every CSP.

- Cloud control plane logs: Recording actions taken against your resources deployed in your cloud environment. Include the creation, deletion, and updating of resources along with the access of data stored in PaaS services such as cloud storage buckets.
- Network-layer logs: Each of the cloud providers offers a logging type that captures the IP address, port, and packet size of traffic flowing inbound and outbound of virtual network interfaces.
- Platform/OS-layer logs: When leveraging infrastructure as a service (IaaS), such as an EC2 instance, GCP Compute, or VM, OS-layer logs can be captured with agent-based solutions similar to endpoint monitoring. Some platforms and other resources may also have their own logging capabilities beyond what is generated by the control plane.
- Application-layer logs: Unique to IaaS and function as a service (FaaS) workloads, applications deployed in the cloud can be instrumented to export logs to a central monitoring or logging solution.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

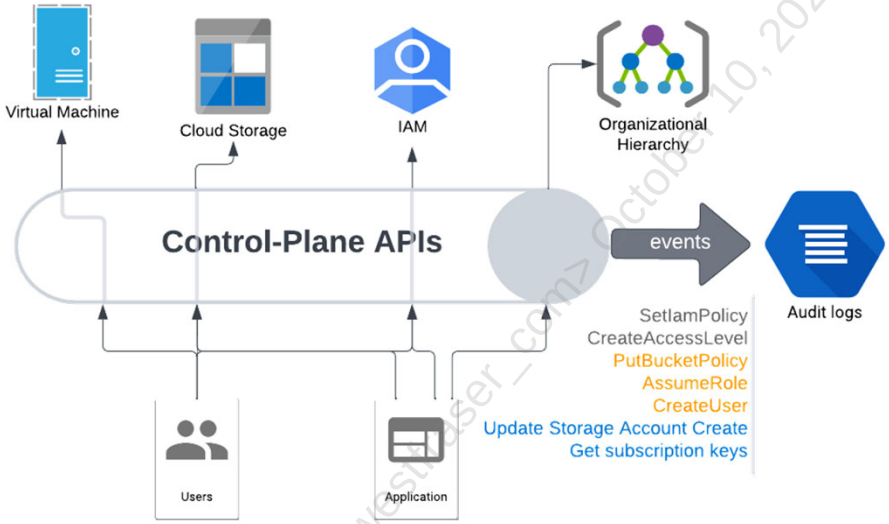
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cloud Events: Control-Plane Logging 101

Control-Plane Layer Logging

- Every service is responsible for writing events, actions taken on cloud resources.
- All CSPs have a default level of control-plane logging which cannot be disabled and additional logging which must be enabled.



Control-plane logs, bespoke to every cloud service provider (CSP) and identity provider (IdP), are the most important log types from a security monitoring perspective. They track authentication, interactions through the API and GUI interface, and the deployment of assets within the cloud. Each cloud service provider has a default level of control-plane logging that is enabled by default and cannot be disabled. Unfortunately, that default level varies widely between cloud providers, as do the default retention settings. These should be reviewed, and policies and standards should be deliberately set and enforced for this critical log data.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Control-Plane Logs By Cloud Provider

Provider	Service / Log Name	Log Storage	Log Query
AWS	CloudTrail	S3 (default)	Filters (CloudTrail Event History), SQL (Amazon Athena)
		CloudWatch Log Group (optional)	Full-text Search (Log Group), Log Insights Query Language (CloudWatch Log Insights), SQL (CloudWatch Metric Insights)
		CloudTrail Lake	Structured Query Language (SQL)
Azure	Activity log	Azure Monitor (Activity log)	Filters & Full-text Search
		Log Analytics or Azure Data Explorer (export required)	Kusto Query Language (KQL)
Google Cloud	Cloud Audit Logs	Cloud Logging Bucket(s)	Logs Explorer (Logs Explorer Query Language)
		Cloud Logging Bucket(s) with Log Analytics	Log Analytics (SQL)

AWS provides multitudes of sensor data from all of its 200+ services. CloudTrail is the ubiquitous logging service to which all AWS services write logs.

AWS CloudTrail Events[1]
All services will write their management-plane events to CloudTrail within the scope of the account it executes in by default. You can find both read and write events in the CloudTrail logs spanning all services by default. The capturing of data-plane events for select services is available on an opt-in basis.

The CloudTrail service stores logs in S3 by default, but you can also optionally store them in a log group. The S3 logs are written in a compressed JSON format and can be filtered and viewed in the CloudTrail service under the Event History (see limitations below). However, if more flexible querying is required, logs can also be sent to a CloudWatch Log Group, where full-text search capabilities are available within the Log Group itself and a custom query language is also available for more advanced queries under CloudWatch Log Insights. If you prefer the structured query language (SQL), CloudWatch Metric Insights allows you to perform SQL queries.

If you need to reference data that is older than what is retained in the Log Group, Amazon Athena is another option that can be used to query data directly from S3 using SQL. In order to use Athena to query the logs, there is some additional setup required and there is a charge to use the service to read data from S3. Partitions allow you to more easily reduce the scope of your queries to ensure they are not scanning the entire bucket, but this requires additional upfront design to add meaningful prefixes to the log files.

Another option is a managed service from AWS for centralizing or aggregating your CloudTrail data from all accounts and regions in your organization, called **CloudTrail Lake**.[2,3,4] Besides centralizing your logs, other advantages of CloudTrail Lake include event immutability, simplified data retention settings, and the ability to query your logs using the structured query language (SQL).

CloudTrail Event History[5]
While not a pattern for log capture and aggregation, it's worth mentioning the scope of events within

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

CloudTrail Event History. CloudTrail Event History is the AWS console UI that allows you to view regional CloudTrail events within your account. This log is limited to 90 days of events and will only ever display management-plane events. No cross-account or cross-region aggregation is available.

It is the place to find control-plane events. The log can be accessed centrally from Azure Monitor and can also be viewed from menus within a subscription, a resource group, or even individual resources.

Azure's "Activity Log"[6]
Accessing the logs outside of Azure Monitor will automatically apply the appropriate filter for the resources you were interacting with when opening the log. While the "Activity log" does support full-text searches and filters, if you would like to query it like other logs in Azure or correlate it with resource-specific logs, you will need to "Export Activity Logs" and choose to send it to the appropriate Log Analytics Workspace in the Diagnostic Settings configuration. Once the log data is exported to Log Analytics, the Kusto Query Language (KQL) can be used to analyze the log data or join it to other logging tables.

Google Cloud's "Cloud Audit Logs"[7]
These logs are configured in "Cloud Logging" and by default can be queried with "Logs Explorer" using a query language specific to Logs Explorer. If SQL is preferred or correlation with other tables is desired, the log bucket can be configured for **Log Analytics**,[8] which leverages Google's BigQuery service to create a data lake.

1. https://sec549.com/id525
2. https://sec549.com/id523
3. https://sec549.com/id524
4. https://sec549.com/id526
5. https://sec549.com/id410
6. https://sec549.com/id527
7. https://sec549.com/id528
8. https://sec549.com/id529

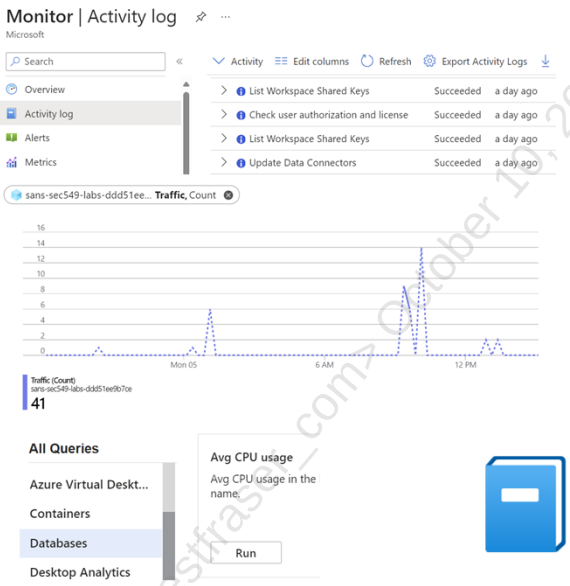
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Control-Plane Logs: Azure Activity Logs

- The **Activity log** is automatically recorded and available via resource, subscription, and Azure Monitor menus in the console.
- **Platform metrics** are also automatically generated and sent to Azure Monitor for Metrics.
- **Resource logs** are disabled by default but can be enabled on a per service / per resource basis.



In Azure, the Activity log and Platform metrics are automatically generated and stored. The Activity log can be accessed from various resource menus, including subscription and resource groups that contain the resource, and in Azure Monitor. Platform metrics are stored in Azure Monitor Metrics. However, these logs and metrics are related to interactions with Azure where actions were taken to create, modify, or delete a resource or its configuration. It does not include changes related to the operations and usage of the service or resource. In order to get information about how resources or services are being used in Azure, Diagnostic settings are modified by the customer to include the specific types of events the customer would like to be included in the logs. What is interesting is that since the Activity log itself is a resource, it also has Diagnostic settings that can be used to send specific log event categories to other monitoring, storage, or alerting services. These diagnostic settings can be accessed via the Export Activity Logs menu when viewing the Activity log in the web console. Any logs that are sent to a log analytics workspace are available in Azure Monitor and can be queried with the Kusto Query Language (KQL).

References:

- Overview of Azure platform logs - Azure Monitor | Microsoft Learn: https://sec549.com/id543
- Diagnostic settings in Azure Monitor - Azure Monitor | Microsoft Learn: https://sec549.com/id544

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Control-Plane Logs: Azure Activity Log Events

- **Activity Log Events**
  - Changes to the configuration of a resource
  - Creation or deletion of a resource (does not include Entra ID identities)
  - Usage and creation of security credentials

- **Example Event types:**
  - Create
  - Update
  - List
  - Delete

Activity logs focus on the changes made to resources or resource configurations through the control-plane APIs. If the changes are made by interacting with the service itself, these events are not included in the Activity log. For instance, if you create or delete a Kubernetes cluster in the Azure Kubernetes Service (AKS), these events will show up in the Activity log. However, if after the cluster is created you deploy a container to the cluster, that event would not be recorded in the Activity log. This is where Diagnostic settings and Resource logs, which typically send the log data to tables in Log Analytics, become important.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Control-Plane Logs: Azure Resource Logs

- **Azure Resource Log Events**
  - Enabled per resource using Log Analytics (LA) diagnostic settings
  - Resource usage
  - Data modifications
  - Application changes

- **Example Events:**
  - PutBlob
  - GetBlob
  - stdout/dev
  - stdout/prod

After logs are enabled in Diagnostic settings for a resource, if the resource does not have a classic logging option (e.g., Storage Analytics[1,2]) or does not yet have a Log Analytics Diagnostic setting (e.g., NSG Flow Logs), tables will be available in the Log Analytics Workspace you selected in Diagnostic settings. A few logs are stored outside of Log Analytics. For instance, Azure Blog Storage logs have a classic storage option where they are stored in a $logs storage container. NSG flow logs[3] are also stored in a storage container. These logs are viewable with storage explorer products like "Microsoft Azure Storage Explorer". While blob storage can now be logged to a Log Analytics workspace instead of a storage container, NSG flow logs do not yet have this option. However, VNet flow logs4 are integrated with Log Analytics and Azure Monitor through Traffic Analytics.

1. https://sec549.com/id545
2. https://sec549.com/id546
3. https://sec549.com/id519

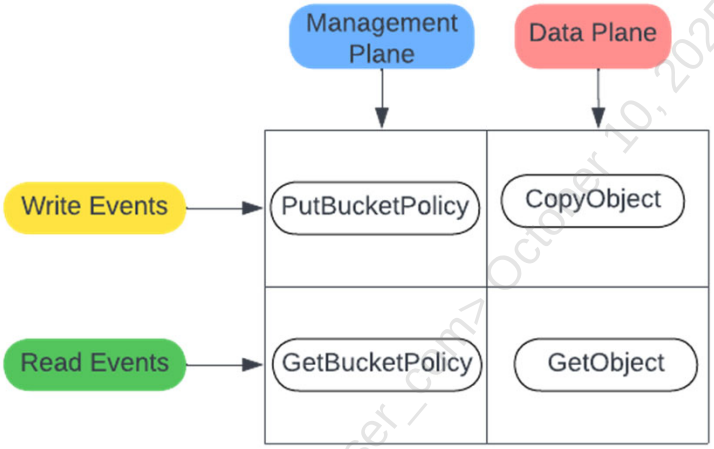
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Control-Plane Logs: AWS CloudTrail

- **Management-plane events** are automatically recorded in every AWS account. They can be queried from the Event History service.
- **Data-plane events** are disabled by default but can be enabled on a per-service/per-resource basis



AWS CloudTrail[1] is a service that records every API call that occurs within your Amazon environment. The logs created by this service are also referred to as trails. Unfortunately, the use of the same name for both the service and the logs it creates can be confusing.

Each API call is recorded as an event, which is then batch-written to an Amazon S3 bucket. These CloudTrail events can provide detailed information about each API request, the identity of the user who made the request, and the source of the request (e.g., the AWS Console, CLI, a third-party application, or another AWS service), and they sometimes include the response.

CloudTrail events can be classified into two categories: management-plane events and data-plane events. They can also be classified as either read or write events. The classification of an event determines whether it is captured by default, how it can be aggregated within AWS, and whether the record contains the API response.

1. https://sec549.com/id243

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Control-Plane Logs: AWS CloudTrail Events

- **Management-Plane Events**
  - Changes to the configuration of a resource
  - Creation or deletion of a resource including IAM resources
  - Usage and creation of security credentials
- **Key Examples:**
  - Security Token Service Events: *AssumeRole*
  - Creating EC2 Instances: *RunInstances*
  - Changes to S3 Buckets: *PutBucketPolicy*
  - Creating Credentials: *CreateAccessKey*
- **Data-Plane Events:**
  - Record actions taken on data stored in the cloud
  - Also include the invocation of serverless applications
- **Key Examples:**
  - S3 Read Events: *GetObject*
  - S3 Read Events: *PutObject*
  - Lambda Events: *InvokeFunction*

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Management-plane events in AWS are automatically recorded, captured per account, and retained for 90 days by default. All events are recorded regardless of whether the action was taken via the management console, the AWS command-line interface (CLI), or AWS SDKs. Management-plane events include creating, modifying, or deleting AWS resources, as well as logging in or out of the AWS Management Console. These events are recorded in trails via the AWS CloudTrail service.

Here is an example of how management-plane events in AWS can be useful for threat detection:

- *AssumeRole:* The event is written when IAM roles are assumed, and temporary session credentials are issued.
- *RunInstances:* An event that may indicate an adversary attaching an IAM role to a new EC2 instance in order to extract and use temporary session credentials
- *CreateAccessKey:* An event that may indicate an adversary has generated an API key for an existing, possibly privileged, user.
- *PutBucketPolicy:* An event that may indicate the malicious update of the resource-based policy on an S3 bucket to allow an external party access

The equivalent to AWS management-plane events in Google Cloud is Cloud Audit Logs, which are also enabled by default and cannot be disabled. Cloud Audit Logs capture activity in your Google Cloud account and provide a record of the activity, including who made the change and when it was made.

In contrast to management-plane events, data-plane events are not enabled by default[1] in AWS. Data-plane events refer to actions such as reading, writing, and updating data stored in the cloud, as well as the execution of Lambda functions. While data-plane events can provide valuable insight and help with security and compliance, they can also generate a large volume of log data over time, which can result in additional costs. As a result, organizations must carefully consider the cost versus risk when deciding whether to enable data-plane events in their AWS environment.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Here is an example of how data-plane events in AWS can be useful for threat detection:

- *GetObject:* A read event written when an object is retrieved from an S3 bucket. Useful when determining who is accessing your objects and from where.
- *PutObject:* A write event written when an object is uploaded to an S3 bucket. This event will be recorded if the bucket is within the scope of the trail.
- *InvokeFunction:* An event written when a serverless function is called. An important event when investigating the compromise of event-driven architecture.

S3 data-plane logging can be enabled on a per-bucket/prefix level, scoped to capture only read or write events, or a trail can be configured to capture events on "All Current and Future Buckets." There may be hesitation to enable S3 data-plane logging on "All Current and Future Buckets" due to the cost. When evaluating the benefit of S3 data-plane logs, many organizations might choose to enable data-plane logging only on buckets containing high-value data.

Scoping an S3 data-plane trail to "All Current and Future Buckets" ensures that external S3 bucket destinations are recorded when objects are moved via the GetObject and PutObject events. Without this broad scope, the PutObject event is not recorded in the source account and could result in missed indications of data movement to an external account.[2]

1. https://sec549.com/id244
2. https://sec549.com/id245

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

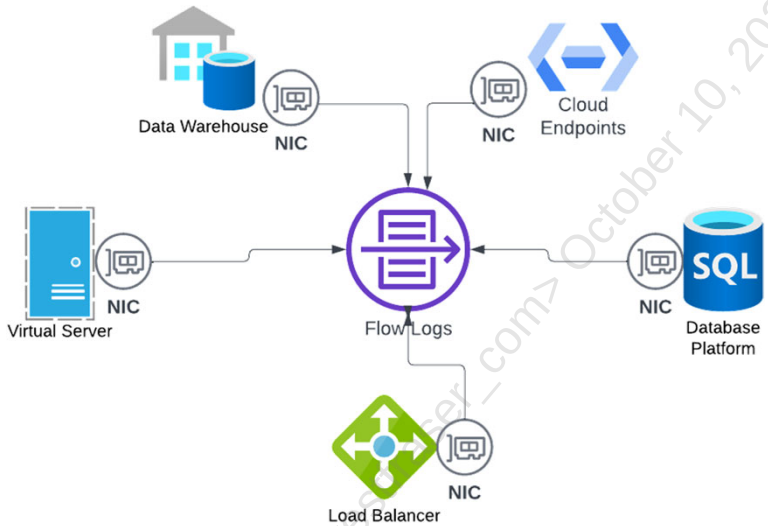
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cloud Events: Network Layer Logging 101

Network-Layer Logging

- Flow logs capture metadata around the network traffic, not the packet data itself.
- Flow logs are available on any resource which has a virtual network interface such as virtual machines, load balancers, and some database offerings.



The cloud is built on a series of abstractions to provide ease of use for customers while also separating the underlying implementation decisions made by the cloud provider. These abstractions serve as the technical foundation for the shared responsibility model in cloud computing.

The architecture underpinning the cloud inherently limits the breadth of information that can be accessed, as cloud providers need to protect the privacy and security of their customers by preventing them from interfering with each other in a multitenant environment. An example of this limited visibility is flow logs.

Flow logs are a feature offered by cloud providers that capture metadata about IP traffic flowing to and from network interfaces within their environments. This metadata includes information about the source, destination, and protocol of the IP flow, but does not include the data payload itself.

Flow logs provide visibility into normal traffic patterns and the ability to identify deviations. They are particularly useful for security purposes, as they contain metadata about IPs, ports, and protocols that allow analysts to differentiate between legitimate and unauthorized traffic. This can help them detect and respond to potential threats. When coupled with threat intelligence service, flow logs can help identify malicious traffic from known botnets and command and control servers or help investigate suspicious egress traffic.

So, what are the flow log limitations? Flow logs are not sufficient for use cases that require SSL inspection, as they are unable to provide visibility at the packet level. They can only capture metadata about IP traffic, rather than the data payload itself. Instead, traffic mirroring coupled with third-party appliances deployed in the cloud is often utilized when full packet capture is required.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Network Layer Flow Logs by Cloud Provider

Provider	Service / Log Name	Aggregation Interval	Storage / Retention
AWS	VPC Flow Logs	1 or 10 (default) Minutes	CloudWatch (5 Minutes), S3 (10 Minutes), or Kinesis Firehose
			Based on delivery location retention settings
Azure	Network Watcher VNet (preview) or NSG Flow Logs	1 Minute (fixed)	Azure Network Watcher – Azure Storage
			Retention - 0 (forever) – 365 Days
Google Cloud	VPC Flow Logs	5 (default) or 30 Seconds, 1, 5 , 10, or 15 Minutes	Cloud Logging
			Retention – 30 (default) Days or 1 – 3650 Days

Flow logs are sampled and/or aggregated network traffic details that can provide visibility into traffic flow and enforcement of network security rules.

AWS Virtual Private Cloud (VPC) Flow Logs:[1] AWS VPC Flow Logs are used to capture network traffic in and out of all network interfaces, including the source and destination IP addresses. Network interfaces are connected to many different resource types in AWS, such as Amazon Elastic Compute Cloud (EC2) instances and load balancers.

In AWS, flow logs can be created for a VPC, subnet, or network interface. If a flow log is added for a VPC, all network interfaces in that VPC would be included. Logs can be stored in a CloudWatch Log Group, Amazon S3, or streamed through a Kinesis Data Firehose, where they can be retained based on the final storage location's retention settings.

In **Azure, Network Security Group (NSG) Flow Logs**[2] can be used for monitoring traffic in and out of the security groups attached to either network interfaces or subnets. There is a separate service called **VNet Flow Logs**[3] in preview that, for certain preview supported regions, supports adding flow logs for an entire virtual network (VNet). Flow logs are store in the Azure Network Watcher service, which is backed by Azure Storage. Retention can be set to forever by setting the "Days" setting to 0 or to the number of days up to 1 year (365 days). **Traffic Analytics**[4] is a separate service that can be used to help with monitoring and viewing the flow log data in Log Analytics.

In **Google Cloud, VPC Flow Logs**[5] are enabled on a subnet level. However, adjusting the filtering, sampling, and aggregation settings allows customers to focus on the granularity and quantity of logging needed for each subnet. Logs are stored in the Cloud Logging service and are retained for 30 days by default but can be set to any number of days up to 10 years (3650 days). While each cloud provider offers some visibility into container networking, Google Cloud also has an option to enable "intranode visibility," which provides access to information about network traffic that doesn't leave a node or container instance.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

1. https://sec549.com/id518
2. https://sec549.com/id519
3. https://sec549.com/id520
4. https://sec549.com/id521
5. https://sec549.com/id522

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Network Layer Packet Capture by Cloud Provider

Provider	Service / Log Name	Scope	Destination / Quotas / Limit
AWS	VPC Traffic Mirroring	Network Interface	Gateway Load Balancer Endpoint pointing to packet capture infrastructure
			Max 10,000 sessions/targets/filters per account, not all instance types supported
Azure	Network Watcher Packet Capture	Virtual Machine	Azure Storage Account and/or File System
		Virtual Machine Scale Set	Time limit configurable up to 18000 seconds or 5 hours; 10,000 sessions per region per subscription
Google Cloud	VPC Packet Mirroring	Subnet, Network tag, Instance	Network Load Balancer pointing to packet capture infrastructure
			Duplicates traffic on interface used to mirror traffic

Each of the cloud providers offers packet capture capabilities for organizations needing more visibility into the individual packets and even packet contents in their virtual networks. There are some differences in the way these services are configured. AWS requires a configuration for each network interface that requires traffic mirroring. Google Cloud allows you to set up a policy that will apply to any Compute Engine instances located within a subnet, including a specific network tag, or by selecting the specific instance. Azure is set up by selecting the Virtual Machine or Virtual Machine Scale Set for which you want the capture to apply. Pay attention to the quotas, limitations, and costs associated with leveraging these services. Azure allows you to log the packets to the file system, a storage account, or both, while both AWS and Google Cloud recommend you mirror the traffic to a load balancer endpoint, which sends it to a cluster of packet capture instances.

References:

- What is Traffic Mirroring? - Amazon Virtual Private Cloud: https://sec549.com/id538
- Traffic Mirroring quotas and limitations - Amazon Virtual Private Cloud: https://sec549.com/id539
- Packet capture overview - Azure Network Watcher | Microsoft Learn: https://sec549.com/id540
- Manage packet captures for VMs - Azure portal - Azure Network Watcher | Microsoft Learn: https://sec549.com/id541
- Packet Mirroring | VPC | Google Cloud: https://sec549.com/id542

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cloud Events: OS and App-Layer Logs

Operating System-Layer Logs

- Telemetry from operating systems such as SysLogs or IIS Logs
- Events from a container orchestration system such as Fargate, ECS, AKS, or GKE
- Leverage **CSP unique logging agents** to capture OS-layer logging

Application-Layer Logging

- Events and metrics generated by applications
- When applications are hosted as containers or on IaaS often application-layer logging can be configured to write to cloud-native logging streams
- Leverage **CSP logging agents** to capture application-layer logging

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

The OS Layer

Operating system (OS)-layer logs contain detailed information about a user's interactions with the OS and file system, as well as the applications and services running on the host. They can be obtained using Syslog (on Linux systems) or WMI (on Windows systems). These logs have traditionally been used to troubleshoot issues, monitor system activity, or used to investigate security incidents.

To minimize the configuration of ad hoc network-layer collection, many cloud service providers (CSPs) have implemented the use of agents within the operating system. These agents transparently send logs to a central location, such as Log Analytics or Event Hub, for storage and analysis. This approach allows for more efficient collection and transportation of log data.

The Application Layer

Application-layer logging is available in custom-developed applications deployed using infrastructure as a service (IaaS) and function as a service (FaaS). As organizations move away from owning and managing lower layers of the IT stack, this layer becomes increasingly important for capturing authentication, authorization, and action events. Telemetry pulled from the application layer can provide more visibility into malicious activity than visibility at the network layer. For example, monitoring IP traffic may allow an organization to detect suspicious behavior, but it may not provide enough information to confirm that an account has been compromised.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Control-Plane OS and App-Layer Logs by Cloud Provider

Provider	Service / Log Name	Primary Concepts	Description
AWS	CloudWatch Logs	CloudWatch Logging Agent	Collect system logs from EC2 instances
		Container Insights	Collect, aggregate, and summarize metrics and logs for ECS and EKS
		Lambda Execution	Collect Lambda function telemetry and logs
Azure	Azure Monitor	Azure Monitor Agent	Collect system logs from Azure VMs
		Container Insights	Collect container logs from AKS clusters
		Application Insights	Collect application performance and usage data for Azure App Services and Functions
Google Cloud	Cloud Logging	Ops Agent	Collect system logs from Compute instances
		GKE Logging Agent	Collect container and control plane GKE logs
		Cloud Logging Client SDK	Write application logs to Cloud Logging

Each of the cloud providers has very similar services and capabilities for capturing operating system (OS) level and application level log data:

AWS
AWS CloudWatch collects monitoring and operational data in the form of logs, metrics, and events, providing a unified view of AWS resources, applications, and services that run on AWS and on-premises servers. The AWS CloudWatch Logs Agent is a software package that can be installed on servers to send logs to an AWS CloudWatch Log Group. The CloudWatch Logs Agent supports both AWS EC2 instances and servers not running inside AWS. The agent allows for the collection of log data from various sources, such as application logs or system logs, and its transmission to CloudWatch for monitoring, storage, and analysis.

AWS Container Insights is a feature integrated within Amazon CloudWatch that provides detailed monitoring, logging, and diagnostics for containerized applications running on Amazon ECS (Elastic Container Service), Amazon EKS (Elastic Kubernetes Service), and AWS Fargate.

Similarly, AWS Lambda functions automatically send execution logs and custom logging statements to CloudWatch Logs groups for analysis.

Azure
Azure Monitor collects data from various sources, including application telemetry, infrastructure monitoring, network monitoring, and user analytics, to provide a centralized workspace for log analysis, alerts, and notifications.

The Azure Monitor Agent is a software package installed on Azure virtual machines and other servers. The agent collects log data from the server and sends that to the configured Azure Monitor log analytics workspace.

Azure Monitor's Container Insights collects and analyzes container logs from Azure Kubernetes clusters.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Azure App Services and Azure Functions can enable Application Insights to gain better visibility into their applications.

Application Insights collects telemetry data from applications, including request rates, response times, failure rates, dependencies, exceptions, and custom logging statements.

GCP

Google Cloud Logging, part of Google Cloud's operations suite (formerly Stackdriver), is a fully managed service that allows you to store, search, analyze, monitor, and alert on log data and events. The Google Cloud Ops Agent collects logs and metrics from compute instances and sends them to the Cloud Logging service.

Google Kubernetes Engine (GKE) audit logging is a feature that records user activities and API calls occurring in a GKE cluster. These logs include admin activity logs, data access logs, and container logs.

Google Cloud Function logs are not automatically written to Cloud Logging. Development teams will need to use the Cloud Logging client libraries to write log statements to the Cloud Logging API.

References:

- AWS CloudWatch Metrics, logs, and traces with the CloudWatch agent https://sec549.com/id557
- AWS CloudWatch EKS Container Insights: https://sec549.com/id558
- AWS CloudWatch Logs with AWS Lambda: https://sec549.com/id559
- Azure Monitor Virtual machines: https://sec549.com/id560
- Azure Application Insights: https://sec549.com/id561
- Azure Monitor Container Insights: https://sec549.com/id562
- Google Cloud Ops Agent: https://sec549.com/id563
- GKE Logging: https://sec549.com/id564
- Cloud Functions Logging : https://sec549.com/id565

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cloud Logging: Building Findings and Insights

- Logs are just events that need to be analyzed
- Some events will be meaningful, and others will not
- Findings or insights are events or a combination of events that have meaning or require action
- Managed cloud services that generate findings or insights can help you get started quickly

Telemetry data from various sources, including the control plane, network layer, OS layer, and app layer, can be analyzed in the cloud environment to generate findings and insights. It is important to distinguish between log sources, such as events from the control plane, and the findings that can be derived from analyzing these logs. While it can be valuable to use cloud-native solutions to generate findings and insights "at the edge" in the cloud environment, it is also important to export these findings into a logging solution that is used by the entire security operations center (SOC), rather than allowing them to become lost in separate dashboards.

In this course, you will be working to aggregate and export both log telemetry data (CloudTrail and VPC Flow Logs) and insights (Security Hub Findings) from the cloud environment.

Coming up, we will look at some of the threat monitoring capabilities, but some of the other services that generate findings in the cloud are:

Azure Advisor:[1] A series of free checks, recommendations, and even remediations to help improve the security, reliability, operational excellence, performance, and cost associated with your Azure operating environment. This service can help you get immediate insights into the health of your Microsoft cloud environments before you have implemented other, more detailed capabilities.

Microsoft Defender for Cloud:[2] The free version of Cloud Security Posture Management (CSPM) will include CIS benchmark type insight into the health and security of your cloud environments, but with the paid Defender CSPM, more advanced checks and correlated checks are included, along with governance ticketing workflows. There are also subscriptions for workload and storage protection. Findings are stored and displayed in a number of places inside the Azure web console as well as being accessible via APIs and through a central dashboard.

AWS Trusted Advisor:[3] A series of checks looking for best practice configurations across services. Basic checks within Trust Advisor are not strictly security related. Recommendations are available to customers without paying for a premium subscription covering security, cost optimization, performance, fault

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

tolerance, and service usage limits.

AWS Security Hub Findings:[4] Provides a standardized log format (AWS Security Finding Format (ASFF)) to ingest, display, and analyze findings from numerous AWS Security Services and from third-party providers. Security Hub is much more than "just another dashboard." Most of your AWS events can be centralized into the Security Hub dashboard, ranging from GuardDuty findings to AWS Config checks and findings from Trusted Advisor.

Google Cloud Recommender[5] **& Profiler:**[6] Google Cloud Recommender and Profiler are two services in Google Cloud that can provide insight into the health of your cloud environment and provide recommendations for improvements.

Google Cloud Security Command Center:[7] Provides vulnerability and threat intelligence findings by centralizing findings and inventory. Includes asset inventory, discovery and misconfiguration, vulnerability, and threat details.

1. https://sec549.com/id598
2. https://sec549.com/id599
3. https://sec549.com/id600
4. https://sec549.com/id216
5. https://sec549.com/id601
6. https://sec549.com/id602
7. https://sec549.com/id603

Reference:

- Image: Diyajyoti/Shutterstock.com

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cloud Managed Detection Services

Cloud providers offer detection services for establishing a baseline:

AWS GuardDuty	Defender for Cloud – Security Alerts and Incidents	GCP - Sensitive Actions
• Signature-based detections integrating threat intelligence feeds • Categories of findings include those affecting EC2, IAM, Kubernetes Clusters, S3 buckets and findings targeting OS-layer malware	• Alerts covering the cloud-control plane and OS-layer • Comprehensive coverage, alerting subscribers to detected threats using machine learning and threat intelligence feeds to augment findings.	• Small portfolio of signature-based detections. • Reports when certain high-risk actions are performed in your organization or project

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Let's review the offerings from the cloud providers when it comes to native detection on the cloud plane and operating systems hosted in the cloud.

AWS GuardDuty[1]
The GuardDuty service identifies actionable security issues that can be addressed. While it is not enabled by default, it can be activated for an additional fee. Please note that the customer will incur additional costs not only for enabling the GuardDuty service, but also for the logging streams that it uses. GuardDuty is a robust offering for threat detection in AWS with detection types spanning multiple products, including EC2, Kubernetes, and S3 buckets. As IAM is frequently a target for attackers, GuardDuty will alert its customers when suspicious activity is identified within the IAM service. In addition to detections based strictly on known signatures, findings are informed by an AWS threat feed consisting of known bad IP ranges. Customers can augment this feed with their own list of known bad IP addresses.

Defender for Cloud Security Alerts and Incidents[2]
Microsoft provides a native detection capability in a similar vein to AWS GuardDuty but geared toward their Azure cloud platform.

Defender for Cloud consists of a collection of tools, one of which is detection and alerting capabilities for your Azure deployment. Alerting is categorized as follows:

- Alerts for Windows Machines
- Alerts for Linux Machines
- Alerts for Azure App Service
- Alerts for Containers
- Alerts for SQL Databases
- Alerts for open-source relational databases
- Alerts for Resource Manager

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

- Alerts for DNS
- Alerts for Azure Storage
- Alerts for Cosmos DB
- Alerts for Azure Network Layer
- Alerts for Azure Key Vault
- Alerts for Azure DDoS Protection

GCP: Sensitive Actions:[3] A component of Google Cloud Security Command Center (SCC) premium makes determinations as to sensitive actions in your cloud estate and generates findings accordingly. Like all telemetry published in SCC, GCP Sensitive Action findings are available programmatically in addition to being published to the SCC central dashboard. This service can alert you when high-risk actions have been taken, such as a user adding an SSH key, high-powered compute instances are created, or highly privileged roles are bound to principals.

1. https://sec549.com/id217
2. https://sec549.com/id215
3. https://sec549.com/id216

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Security Data Lake Benefits

- Managed detection services will not cover all findings and events
- Customers need to design their own centralized data lakes that include the organizations log sources, queries, detections, and alerts

Security Lake Promises

- Flexible data types allowed from structure to unstructured data
- Cost savings possible with data tiering; "hot" and "cold" layers
- Easier and more "plug-and-play" ingestion allowing for non-standard data sources

In the past decade, centralizing and aggregating security logs have been primarily aimed at feeding the SIEM. However, with increasing retention requirements that can significantly escalate the cost of both on-premises and cloud-based SIEM, some organizations are turning to an intermediary layer called the Security Data Lake. This shift is because a more flexible data lake integrated into your data warehouse architecture can help unlock previously unavailable data for querying, which was previously stored in cold storage.

Moreover, incorporating a Security Data Lake into your pipeline can provide you with another tool to help balance cost, speed, and scale. With a Security Data Lake, analysts can access more advanced, cloud-native analytics tools such as GCP Looker, Azure PowerBI, and AWS Athena, allowing for near real-time querying of security data. This can enable analysts to spot security threats and vulnerabilities much more quickly and efficiently than before.

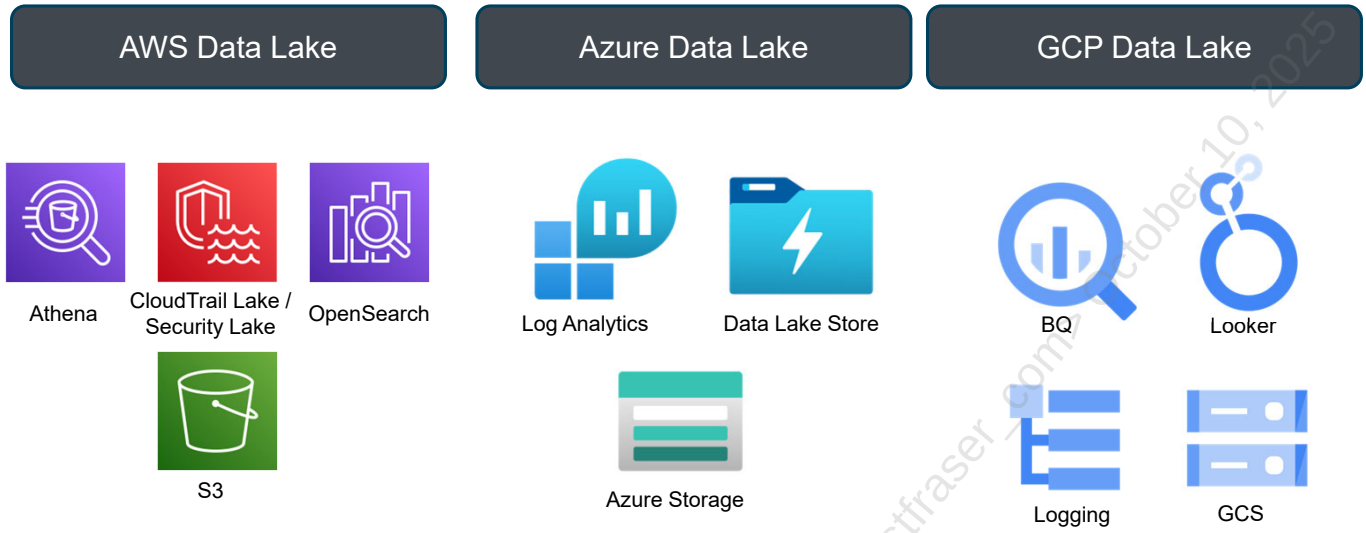
Furthermore, maintaining a Security Data Lake per cloud reduces the egress charges incurred pulling data from each cloud into a centralized SIEM.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Security Data Lake Options



When comparing the architecture of a Data Warehousing pattern used in SIEM design and a Data Lake, it becomes evident that a Data Lake ingests data without significant transformation and normalization processing. With Security Data Lakes, the incoming data sources are kept minimally processed during ingestion and only messaged at the time of query to avoid corrupting the raw data.

What ETL processes might still occur ahead of Data Lake ingestions? Data might need to be augmented with tags for metadata management or sensitive information redacting. The need to conform incoming data to a standard schema is not as critical in Data Lake as it is in traditional data warehousing. Due to its flexible model, analytics tools used to search and query across a Security Data Lake often possess built-in capabilities for data normalization, adjusting the data qualities to suit the analytics tool without modifying the underlying raw data.

AWS

One of the simplest and most effective cloud-native security data lake architectures in AWS comprises only two services: AWS S3 and Athena. Running simple queries against vast unstructured, semi-structured, and structured data sets stored in S3 is easy using Athena.

- Analysts can leverage standard SQL commands in Athena and skip learning another query language.
- Athena is serverless, which means that there is no need to pay for, configure, or manage infrastructure.
- Athena is optimized for high performance, capable of running queries in parallel and returning results in seconds, even for complex queries, which enables the data lake to scale to meet increasing demands.

AWS also has the AWS Security Lake and AWS Open Search (managed Elastic Search) managed services that can provide enhanced data lake architecture capabilities such as data transformation or data metadata collection.

Azure

Azure Log Analytics provides the most straightforward path for building a centralized log analysis hub.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Security teams start with a single log analytics workspace for the tenant. From there, activity, audit, and diagnostic logs are fed into the central log analytics workspace for queries and analysis. The log data can also be sent in parallel to an Azure Storage account for long-term storage. For more details, see the Designing a Log Analytics workspace architecture reference below.

GCP

GCP's Cloud Logging can store, query, analyze, and create metrics for audit log data. Log sinks allow cloud logs to be stream into BigQuery datasets and Google Cloud Storage buckets for further analytics and archival.

References:

- AWS Athena Getting Started: https://sec549.com/id466
- What is Amazon Security Lake? https://sec549.com/id567
- What is Amazon OpenSearch Service: https://sec549.com/id568
- Azure Monitor: Design a Log Analytics Workspace Architecture: https://sec549.com/id569
- Google Cloud Logging: Aggregate and store your organization's logs: https://sec549.com/id570

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cloud Data Aggregation Design Patterns

Log / Event Capture Pattern	Advantages / Disadvantages
Log Events written to **Storage** services	• Lower cost, especially with storage lifecycle settings configured • May require a separate service (e.g., Amazon Athena) or import to query and analyze data • No built-in method for creating dashboards, metrics, alarms, etc.
Log Events written to a managed **logging service** (AWS CloudWatch, Azure Log Analytics, GCP Cloud Logging)	• Higher cost, fewer storage tiers • Built-in dashboarding, metrics, and alerting as part of the service
Events captured by an **event router** (AWS EventBridge, Azure Event Grid, GCP Event Arc) and forward to a processor	• Enables near real-time response to events • Harder to correlate events or metrics, response is limited to per event triggers and transformations

There are three patterns used inside the public cloud providers for aggregating log sources into a centralized location.

Cloud Storage
Sending organizational log data directly into a storage service such as S3, Azure Storage, or GCS will provide the lowest cost option. Compared to logging and data lake services, storage services offer the cheapest price for data. Plus, lifecycle policies can automatically transition data between tiers (warm, cold, archive). However, storage services have no built-in query languages for analysis, dashboards, metrics, and alarms. For this reason, additional integrations will be required to complete the security data lake.

Cloud Logging Services
More advanced logging services, such as AWS CloudWatch, Azure Log Analytics, and GCP Cloud Logging, can ingest log data from the organization. Log files are available to query using the cloud provider's query language to build metrics, dashboards, and alerts. This comes at a cost compared to the cloud storage option. Most organizations will use a combination of both Cloud Storage to meet data retention requirements (e.g., 3 years of audit data) and keep a smaller subset of the data active in the cloud logging service (90 days) to save on the spend.

Event Routing
Organizations that require near real-time data analysis can use the cloud providers' event routing service (AWS EventBridge, Azure Event Grid, and GCP's Eventarc or Pub/Sub) to capture events as they happen and stream the event data into a data processor. Data processors can be event collectors for a SIEM, data streaming services (AWS Kinesis), or queues responsible for performing the extract, transform, and load (ETL) into the data lake.

Considerations for each design pattern
The following data points for AWS illustrate the considerations for choosing from the above design

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

patterns in AWS.

Start with the cost analysis. For example, CloudWatch Log Groups cost $0.50 per GB ingested plus $0.03 per GB stored. CloudWatch Events and Kinesis Firehose costs $1.00 per million events (per region/account) for AWS Events, plus $0.029 for the first 500TB/month for streaming with Firehose. S3 Bucket pricing varies widely between storage classes. However, the most common S3 storage class will be $0.023 per GB for the first 50TB/month, with additional charges for object access and object replication.

Then, consider the amount of time it takes to review the event. Sending telemetry through the EventBridge to a Kinesis Firehose is by far the fastest route, allowing defenders to take action immediately. Delivery to CloudWatch Log Groups and S3 buckets can both be delayed up to 15 minutes. Log delivery via S3 or Log Groups is considered the "slow path." In practice, the delay may only be a few minutes, but during an active incident, the lag may be unacceptable.

Reference:

- AWS CloudWatch Pricing: https://sec549.com/id409

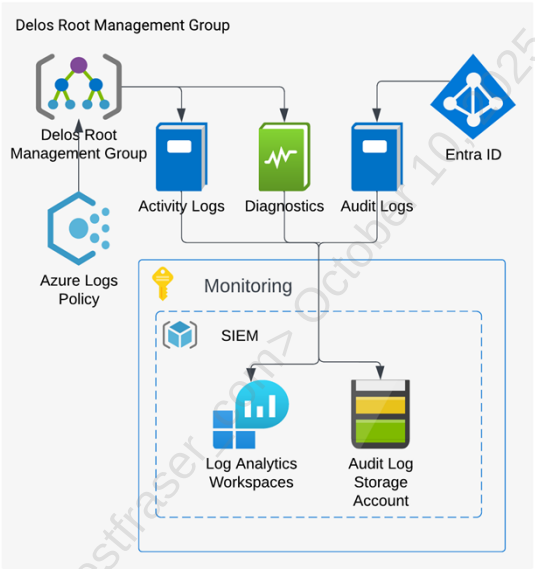
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Azure: Centralized Logging Pattern

- Assign audit logging Azure Policy to the root management group:
  - New subscriptions and resources will automatically route log data to the central monitoring storage account / log analytics workspace
  - Existing subscriptions are marked "out of compliance" and fixed using a remediation task
- Create an Entra ID diagnostic setting to send audit and sign in logs to the monitoring subscription



Centralizing Azure audit logs and resource diagnostics is straightforward using built-in Azure policy definitions. Start by assigning an Azure policy requiring activity and diagnostic logs to route to a central storage account and log analytics workspace to the Delos Root management group. The policy assignment creates a system-assigned managed identity. The managed identity needs two roles to enable it to use the "DeployIfNotExists" condition in the policy. This means that any new subscription that is added underneath the Delos Root management group will automatically have a diagnostic setting configured to send the audit logs over to the resources in the Monitoring subscription. Be aware that the "DeployIfNotExists" effect only applies automatically to new subscriptions. If subscriptions already exist, the policy assignment will highlight the out-of-compliance subscriptions and allow authorized users to create a remediation task manually to deploy the configuration. The deployment for new or existing subscriptions requires the Monitoring Contributor and Log Analytics Contributor roles to be assigned to the managed identity assigned to the policy assignment, as it is the identity that is performing the remediation.

It is important to realize that Entra ID is not subject to the Azure Policy assignments on the root management group. Entra ID will need its own separate diagnostic setting that sends sign-in, provisioning, and high-risk events to the centralized monitoring subscription.

References:

- Azure Monitor: Design a Log Analytics Workspace Architecture: https://sec549.com/id569
- Azure Monitor: How to archive activity logs to a storage account: https://sec549.com/id571
- Azure Monitor: Create diagnostic settings at scale using Azure: https://sec549.com/id572
- Microsoft Entra ID Audit Logs: https://sec549.com/id573

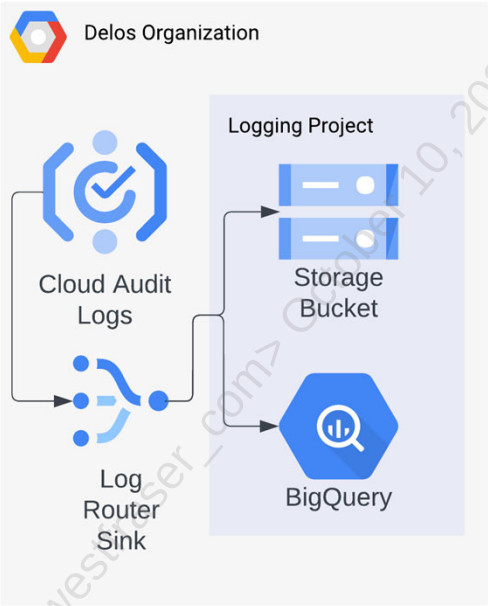
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Google Cloud: Centralized Logging Pattern

- Cloud audit logging captures admin activity logs by default
- Data plane audit logs are not enabled by default and must be enabled for each service
- Log router sinks can send log data from the organization's logging service to centralized storage, BigQuery, or Pub/Sub topics



Google Cloud audit logs are partially enabled by default. Management control plane logs, known as Admin Activity logs, are enabled by default and cannot be disabled. Data plane logs, known as Data Access logs, are not enabled by default and must be enabled by the customer. Data Access Logs can be enabled at the organization level for all services, or on a service-by-service basis to help reduce costs. After enabling Google Cloud audit logs at the organization level, the Logging service has a "Log router" capability that can be used to send logs to a centralized monitoring GCP project. Creating a log router sink will stream all audit log data to a centralized GCS bucket, BigQuery dataset, Pub/Sub topic, Splunk collector, or another GCP project's logging table.

The diagram above shows the log flow for both the storage and data lake options. Different cloud audit log route sinks can send the data into the centralized logging project. Storage bucket and BigQuery dataset resources exist in the project for incident response teams to use for querying, visualizing, and alerting on security events. On the log bucket, you can also enable analytics, which allows you to query information from Log Analytics using SQL. You can also create a linked dataset to enable joining to tables in an organizational BigQuery dataset.

References:

- Cloud Logging Enable Audit Logs: https://sec549.com/id574
- Google Cloud Logging: Aggregate and store your organization's logs: https://sec549.com/id570
- Log Analytics: User SQL and Link to BigQuery: https://sec549.com/id586

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

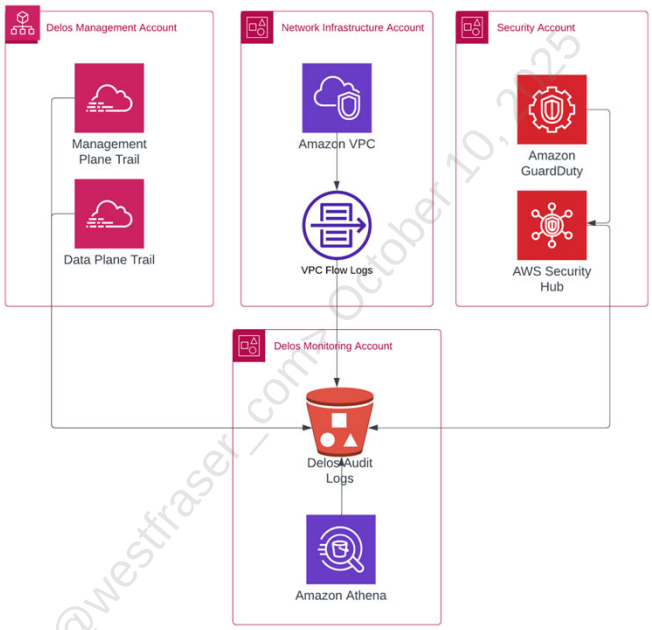
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

AWS: Centralized Logging Pattern

Centralizing log data in AWS is more complicated with cross-account S3 required for:

- management account CloudTrail.
- management and data plane trails.
- VPC network flow logs.
- delegated Security Hub account findings from compliance, threat intelligence, and third-party scans.



Creating a trail in AWS CloudTrail allows you to store log data in an Amazon S3 bucket, providing a record of events over time. You can customize the retention policy for the log data to meet your specific needs. When a trail is not created, management-plane events are still recorded and retained by CloudTrail but are only accessible in the CloudTrail dashboard called Event History.

Trails

A trail is a log that records events within a specific region and account. It can be impractical to configure a trail for every region and account, so AWS provides abstractions to make it easier to set up trails in multiple regions and accounts. When you configure a multi-region trail, the CloudTrail service automatically populates trails in all regions for you. However, a multi-region trail is still created within the context of a single account, and the log files are written to an S3 bucket within that account.

CloudTrail management-plane and data-plane events are configured separately to save money. By closely scoping data access event logging in AWS, organizations can focus on recording events for their most valuable assets. For S3 data events, you can choose to enable event logging for a single bucket or prefix. Furthermore, you can configure the trail to capture all data-plane events or as few as a single event. This allows you to customize the level of granularity for your event logging.

Although management-plane and data-plane events can both be captured on the same trail, it is generally best practice to configure them as separate trails. The trail capturing data-plane events may need to be updated frequently, while the trail configured to record and store management-plane events should remain static and only be updated infrequently, if at all. This helps to ensure that the trail recording management-plane events remains stable, reliable, and predictable.

Organization Trails

An organization trail, which can be configured from the management account of an AWS Organization, makes it easier to manage trails across member accounts. By creating an organization trail, you can ensure that member accounts do not have control over the configuration, update, and enablement of the trail.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Let's take a look at what a multi-account organization trail looks like.

1. Configuration of the trail is orchestrated from the management account but can be delegated to another member account.
2. When you "Enable for all accounts in my organization", the trail is populated to all member accounts and all regions.
3. Although the individual trails will be located in member accounts, only the management account (or its delegate) will have the ability to edit or delete them.

Trail Configuration Options of Note:

- S3 Bucket: Specify an S3 bucket where logs in all regions in all member accounts will be written. This bucket can reside in any account that makes sense for your architecture. It will likely not be in the management account.
- Security configurations such as Log File Validation and Log Encryption with KMS Keys.
- CloudWatch Log Group: Additionally write logs to a Log Group.
- Data-plane events: Set up a trail to record not only management-plane events but also configurable data-plane events for S3, Lambda, or DynamoDB.

VPC Network Flow Logs

Each network has a separate configuration for VPC flow logging. Each spoke network, as well as the transit gateway and firewall logs, should be written to the centralized audit logging bucket. This allows incident responders to use visualization and analysis tools to monitor network traffic from a central location in the organization.

AWS Security Hub

AWS Security Hub provides a centralized view of security insights and findings, along with the compliance status of resources across your AWS accounts. It does not function as a SIEM system and does not store log data, but instead aggregates, organizes, and prioritizes security insights or findings from various AWS services. AWS Security Hub is more than "just another UI"—it is an effective aggregator utilized to pull disparate sources of findings and insights into a single place.

In AWS, many services and resources have the option to designate a member account as a "delegated administrator" for that particular service. This helps to distribute risk across the organization and reduces the need to grant access to the powerful management account to a large number of service administrators. This can help to mitigate risk and make it easier to manage access to the different services.

If you are using AWS Organizations, you can automatically enable Security Hub in all member accounts from the Management Account. However, it is best practice to delegate further Security Hub administration to a separate account, such as an account where your security operations center (SOC) team members have access to configure integrations and export patterns. This helps to distribute responsibility for security across the organization and reduces the risk of relying on a single account for security management.

Imported Findings

Refer to the AWS Security Hub documentation1 for a complete list of services that integrate with Security Hub. Note that integrations are not limited to AWS services—many third-party products allow their findings to be integrated, aggregated, and ultimately exported through Security Hub.

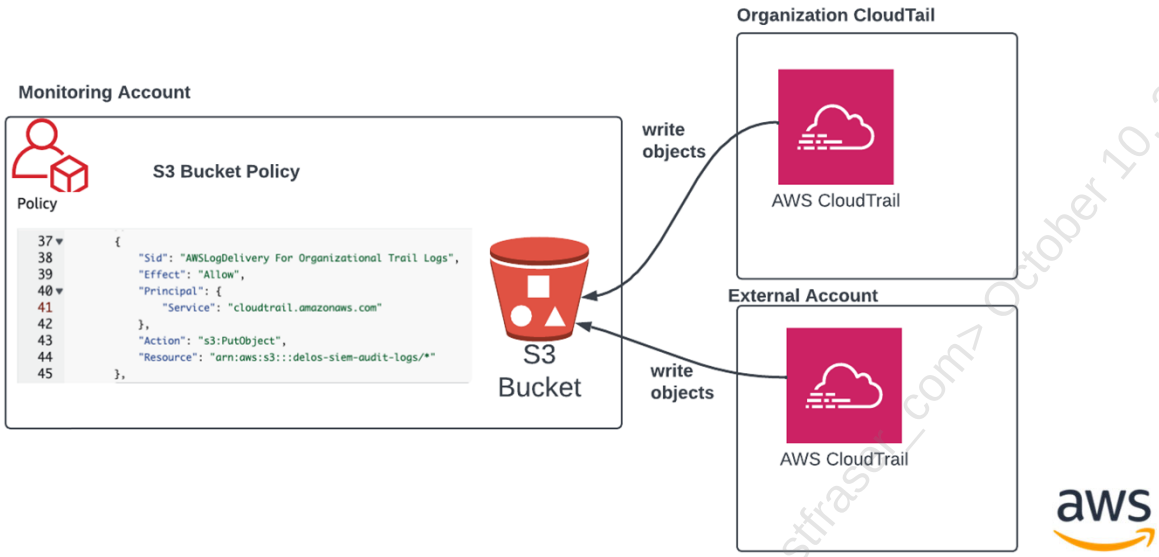
References:

- AWS CloudTrail: Creating a trail for an organization: https://sec549.com/id246
- Configure VPC Flow Logs for centralization across AWS accounts: https://sec549.com/id575
- AWS Security Hub Delegated Administrator: https://sec549.com/id247

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

AWS: Centralizing Audit Logs in S3



In AWS, service principals are not necessarily unique to each AWS account or customer; rather, they are global identities. In some cases, specifically when the service needs cross-account capabilities, granting access to a service principal can create a security risk.[1]

In the above example, a policy is applied to an S3 bucket allowing the internal AWS service, CloudTrail, to write objects to the bucket. CloudTrail across the customer's organization (and possibly external accounts) will write log entries to this central bucket. This policy also authorizes any trail in any AWS account (even accounts external to the organization) to write to the bucket.

This is another example of the "confused deputy" problem.[2] This security issue occurs when an entity (e.g., a service in an external account) that doesn't have permission to perform an action can coerce a more-privileged entity (e.g., a service in an internal account) to perform an action.

Which services can be affected by the cross-account vulnerability? It's not yet clear. Research into this space is very new; however, early indications suggest that any AWS service that can be benevolently used cross-account can also be manipulated and used in a malicious manner.

1. https://sec549.com/id72
2. https://sec549.com/id73

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

AWS: Securing Cross-Account Service Principals

- Random Resource Naming
  - Creating resource names that are hard to guess is a belt and suspenders approach.
  - Conditions specified in resource-based policies should be the primary mechanism for mitigation, as robust security controls should not rely on secrecy to be effective
- IAM Condition Keys
  - aws:SourceOrgId
  - aws:SourceOrgPaths
  - aws:SourceArn
  - aws:SourceAccount

```
{
    "Sid": "AWSLogDelivery For Organizational Trail Logs",
    "Effect": "Allow",
    "Principal": {
        "Service": "cloudtrail.amazonaws.com"
    },
    "Action": "s3:PutObject",
    "Resource": "arn:aws:s3:::delos-siem-audit-logs/*",
    "Condition": {
        "StringEquals": {
            "aws:SourceOrgId": "o-95vbxxkosr"
        },
        "StringLike": {
            "aws:SourceArn": "arn:aws:cloudtrail:*:222222222222:trail/delos"
        }
    }
},
```

Now that we've seen the structural issues unique to AWS service principals, how should we design their access to ensure our accounts are not vulnerable to the class of "confused duty" issues inherent to the platform?

When granting an external party access to an IAM role, an external ID condition is used to mitigate this issue.1 When granting access to a service principal, different global condition keys can be leveraged to limit exactly which service principal can assume the role.

A non-obvious strategy to help mitigate the confused deputy problem in AWS is randomization in naming. You might already append random strings to the end of resources to help conserve the global namespace (as with S3); however, this practice has an additional security benefit. An attacker without knowledge of your naming convention would not be able to access any resources within your accounts.

To help solve this problem, AWS has created several condition keys for customers to use in their resource policies for restricting access to resources from their organization, OU, account, or resource.2

aws:SourceOrgId
Set this condition key to prevent an AWS service-link role from outside your organization from accessing resources.

aws:SourceOrgPaths
Set this condition key to prevent an AWS service-linked role from outside your organization from accessing resources. Similar to the *aws:SourceOrgId* condition, except it provides the ability to be more granular. Use the *aws:SourceOrgPaths* condition to restrict access to a resource from a service principal originating from within an organizational unit (OU) inside the organization.

aws:SourceArn
Set this condition key to prevent an AWS service from being manipulated during transactions between services.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Set the value of this condition key to the ARN of the resource in the request. Typically, this value will be the ARN of the resource assuming the role. It might be the ARN of the CloudTrail trail or, in the example, the ARN listed is that of the response plan resource from Incident Manager.

aws:SourceAccount

Set this condition key to prevent an AWS service from being manipulated during transactions between services. Set the value of this condition key to the account of the resource expected in the request. Typically, this value will be an ID of an AWS account within your organization.

1. https://sec549.com/id75
2. https://sec549.com/id76

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

SANS | CLOUD SECURITY

Lab 5.2

SAR: Centralizing Cloud-Native Events

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Lab 5.2: Summary

In this lab, you:

- Reviewed the Delos cloud centralized event management architecture
- Discovered the centralized Azure monitoring subscription and log analytics workspace
- Discovered the centralized AWS account and S3 logs bucket
- Discovered the Google cloud audits route and centralized cloud storage bucket

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Course Roadmap

Section 1: Cloud Account Management and Identity Foundations

Section 2: Implementing an Identity Perimeter in the Cloud

Section 3: Network Access Perimeters for the Cloud

Section 4: Data Access Perimeters in the Cloud

Section 5: Enabling the Cloud-Focused SOC

- Incident Response in the Cloud
  - Lab 5.1: Threat Model: Managing Cloud-Native Events
- Intra-Cloud Logging and Aggregation
  - Lab 5.2: SAR: Centralizing Cloud-Native Events
- Centralization and Export Patterns
  - Lab 5.3 SAR: Exporting Telemetry to a SIEM – Azure
  - Lab 5.4 SAR: Exporting Telemetry to a SIEM – AWS
  - Lab 5.5 SAR: Exporting Telemetry to a SIEM – GCP
- Course Wrap-Up
  - Lab 5.6: CloudWars: Incident Response and Final Presentation
- Additional Resources

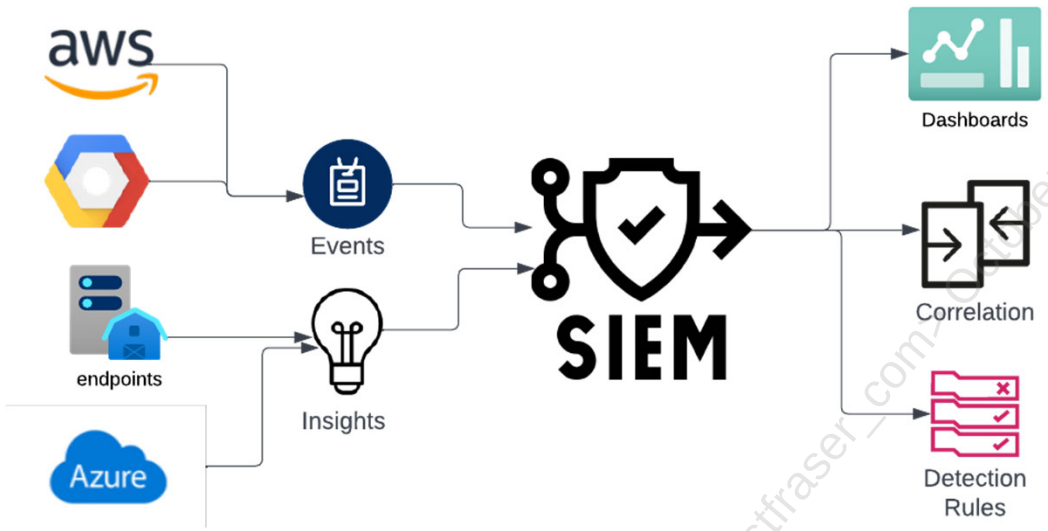
This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Centralizing High-Value Cloud Log Sources



With audit logs stored centrally in each cloud and a cloud-specific data lake for analysis, the next step in the log journey is moving important events from each cloud into a centralized security information and event management (SIEM) system. Centralized logging and monitoring is a crucial aspect of enterprise multi-account multicloud environments. It offers a consolidated view of all important logs generated across various accounts and regions, providing a single point of log access and an opportunity for log correlation.

With a centralized approach, analysts can quickly access all necessary logs from a single source, reducing the time and effort required to sign in to multiple cloud providers to investigate incidents. This can lead to a more efficient and effective incident response process, reducing the risk of analyst burnout and fatigue. Additionally, having all logs in one place allows for easier and more accurate correlation and analysis of data, which can help to identify the root cause of incidents more quickly and accurately.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Third-Party SIEM Solutions and Platforms

Many commercial and open-source SIEM solutions are capable of ingesting important log events from the public cloud providers:

splunk> IBM Security Onion graylog QRadar LogRhythm LIMA CHARLIE

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Most organizations will be using a third-party vendor SIEM product (examples on the slide above) before migrating to the public cloud. In these cases, cloud architects are most likely to aggregate important public cloud provider logs in their pre-existing SIEM solution. This provides a holistic view of an organization's security posture, making it easier to monitor all activities across cloud and on-premises environments from a single platform.

Designing the log path from the public cloud to the third-party solution can be challenging. Architects will need to carefully review the vendor's list of integrations and their documentation before building their design. Differences in the way products, and their integrations, are built will change design decisions. Some products will support pushing data into the SIEM using a data stream, while others will require data to be made available to pull directly from the cloud provider. This module will focus on the data streaming push and pull options available for each cloud provider and how those resources can help aggregate log data from multiple providers.

Note: SANS does not endorse or recommend these vendors. These are for example purposes only.

References:

- Gartner: What is Security Information and Event Management (SIEM)? https://sec549.com/id576
- Third-party SIEM vendors (in no particular order):
  - Splunk: https://www.splunk.com/
  - Graylog: https://graylog.org/
  - Lima Charlie: https://limacharlie.io/
  - IBM QRadar: https://www.ibm.com/qradar
  - Security Onion: https://securityonionsolutions.com/
  - Log Rythm: https://logrhythm.com/

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cloud Provider SIEM Services

Cloud providers also offer SIEM platforms for customers:

AWS: Security Lake / Glue/ Lambda / S3

- No one offering that could be called a cloud-native SIEM and SOAR.
- Instead, AWS has taken the microservices approach of providing the various capabilities of a SIEM (data storage, analytics, ingestion).

Azure: Sentinel

- Cloud-Native SIEM and SOAR
- Direct Competitor to Google Cloud Chronicle
- Natively stream security alerts from Microsoft Defender for Cloud into Microsoft Sentinel

GCP: Chronicle

- Cloud-Native SIEM and SOAR
- Native analytics tools such as Looker
- Direct competitor to Azure Sentinel

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Organizations that are 100 percent cloud hosted without an on-premises footprint are more likely to use a managed SIEM service offered by a public cloud provider over a third-party vendor. Cloud-based SIEM solutions are similar to on-premises solutions; they collect various types of data, arrange and index them, and enable you to ask questions based on the data. These solutions also offer customizable dashboards that you can use to explore the data, create alerts, and deliver context-based security orchestration, automation, and response (SOAR) functionality. The advantage of using a cloud-based solution backed by a service provider is that you don't have to worry about scaling the solution. The disadvantage is a shift in the pricing model. Moving your SIEM to the cloud often changes how you pay for the service, anywhere from ingestion-based licensing to licensing based on workloads executed.

AWS provides no one solution you could call a SIEM offering. Instead, AWS has taken the microservices approach of providing the various capabilities of a SIEM (data storage, analytics, ingestion) in a swath of offerings that can be plumbed together to serve much of the same capabilities. For example, the AWS Security Lake service collects and queries data, while CloudWatch, EventBridge, and Lambda can handle the SOAR functionalities.

Microsoft's Sentinel SIEM platform: The primary benefit of Microsoft's Azure Sentinel SIEM is its proximity with Azure and Windows tools, particularly Windows Defender, Microsoft Advanced Threat Protection (ATP), and Microsoft Cloud Security. This concentration on the Microsoft ecosystem may not be ideal for businesses with multicloud and hybrid infrastructures, despite its usefulness for current Microsoft Windows and Azure users. However, large M365 customers might find there is no better alternative to Microsoft Sentinel.

Chronicle: Google Cloud's Chronicle SIEM and SOAR solution helps enterprises manage and analyze their security data at scale. Chronicle is part of Google Cloud's suite of security tools and aims to leverage Google's BigQuery and Looker services to analyze data and enhance threat detection, analysis, and response.

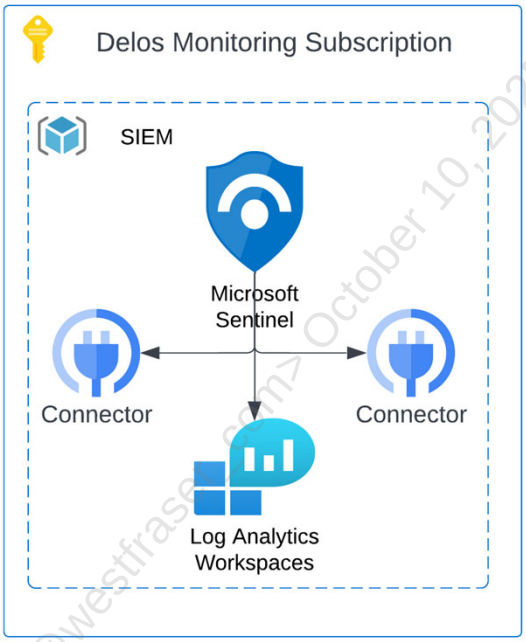
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Microsoft Sentinel SIEM/SOAR Platform

Microsoft Sentinel provides a managed platform for cross-cloud and hybrid security analytics and threat intelligence:

- Extends the capabilities of the centralized log analytics workspace
- Data connectors ingest data from various sources (Entra ID, Defender for Cloud, AWS, Google Cloud, etc.)
- Discovers threats using behavior analysis, threat intelligence feeds, and predefined / custom queries
- Manages incident lifecycle for alerts, triage, response, and resolution



As mentioned early on in this course, architects need to understand where the business is going and help design solutions to meet those requirements. Let's look at an example of how cloud security architects would design their data event and log export architecture for an incident response team that has decided to use Microsoft Sentinel for their SIEM solution. The incident response team has also decided that introducing a third-party vendor, such as Cribl, is not possible for cost and vendor management reasons.

Microsoft Sentinel is a managed security information and event management (SIEM) and security orchestration, automation, and response (SOAR) platform. Sentinel allows businesses of all sizes to detect, investigate, and respond to threats across their entire enterprise.

Data Collection and Analysis
Sentinel stores data in an underlying Log Analytics workspace. Using the Sentinel content hub, Sentinel administrators can install data connectors that pull data from hundreds of different sources, including users, devices, applications, and infrastructure. Data connectors exist for on-premises environments and other public cloud providers, including AWS, Google Cloud, Alibaba, GitLab, and Auth0. Sentinel uses Kusto Query Language (KQL) queries to analyze the logs, events, and other signals, using Microsoft's advanced analytics and machine learning capabilities.

Threat Detection
Microsoft's global threat intelligence and analytics data helps Sentinel identify known and unknown threats, using both rule-based techniques and machine learning-driven anomaly detection. Customers can also discover threats in their environment using predefined queries and Jupyter notebooks.

Incident Investigation and Response
Azure Sentinel helps track incidents from an alert through triage, investigation, assignment, response, and closure. Playbooks help automate responses for common alerts to streamline the time and effort required for incident resolution.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

References:

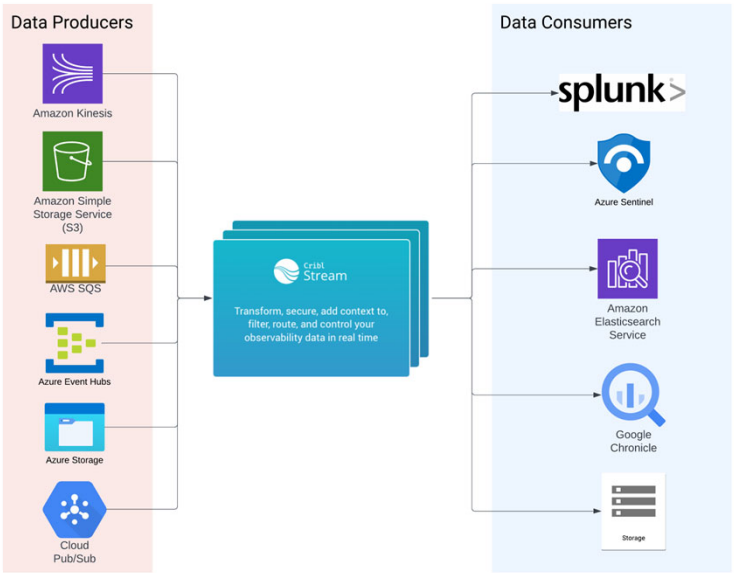
- Microsoft Sentinel: https://sec549.com/id588
- Microsoft Sentinel Data Connectors: https://sec549.com/id589

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cribl: Centralized Data Processing Platform



Cribl is a third-party data processing and observation platform:

- Data Producers stream data to Cribl using a push or pull export pattern
- Cribl Stream normalizes, enriches, filters, and compresses log data / events
- Data Consumers receive processed data from Cribl for analysis

Cribl is a third-party data observability platform that helps organizations manage and optimize data streaming from various sources, including cloud environments. After processing data streams, Cribl forwards the data to various Security Information and Event Management (SIEM) systems. Cribl's supports exporting data from a vast number of real-time data streaming and batch processing pull pattern services. This includes the cloud provider services you have learned about in this section: AWS Kinesis Firehose, AWS Kinesis Data Streams, AWS S3, AWS SQS, Azure Event Hub, Azure Storage Blogs, and Google Cloud Pub/Sub. Cribl supports exporting data to a vast number of destinations, including Splunk, Azure Sentinel, Amazon Security Lake, Elastic Search, Google Chronicle, Datadog, cloud storage services (S3, Azure Storage, and GCS), and many more. Cribl provides several key data processing features before exporting the data to a centralized SIEM:

- **Data Aggregation and Normalization:** Cribl Stream, one of the core components of the Cribl platform, is responsible for collecting data from multiple cloud sources. Data (messages and events) are normalized into a consistent format that the target SIEM can process and analyze. Normalizing the data helps the SIEM correlate and analyze events across the different data sources.
- **Data Enrichment:** Before exporting data to the SIEM, Cribl can enrich the data with additional context. This can include geolocation information, threat intelligence, or any other data that enhances the value of the original log data. Enriched data allows for more detailed analysis and more accurate threat detection within the SIEM.
- **Data Routing and Filtering:** Cribl allows the customer to describe advanced routing and data filters. Filtering data ensures that only relevant data is sent to the SIEM, reducing noise and preventing the SIEM from being overwhelmed with unnecessary data.
- **Data Redaction:** Cribl can redact sensitive information from the data before it is sent to the SIEM, helping organizations meet privacy and regulatory laws. This feature ensures organizations maintain the privacy of customer data and allow for effective security monitoring.
- **Cost Management:** Filtering out irrelevant data, enriching the data that is sent, and compressing data streams helps reduce the volume of data forwarded to the SIEM. This can significantly reduce storage

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

and processing costs associated with running a SIEM, especially when dealing with large volumes of data from enterprise cloud environments.

Reference:

- Cribl Steam Reference Architecture: https://sec549.com/id597

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Public Cloud Data Transfer Patterns

Two design patterns are often used for migrating public cloud data:

Push Architecture

- Supports real-time data streaming and event-driven systems
- Minimizes latency and deliver data is delivered as soon as it is ready
- Requires less noise as the receiver does not need to poll for new data
- Higher complexity managing connections and delivery formats

Pull Architecture

- Supports systems that do not need real-time delivery using periodic updates
- Allows the receiver to control how often data is pulled into the designation
- Increases overhead for the sender and can introduce latency receiving the data
- Lower complexity with a simpler implementation

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Moving data from a cloud provider into a centralized SIEM can use two distinct strategies: push or pull architectures. These strategies determine how the log data is delivered from the source (cloud provider) to the sink (SIEM).

Push Architecture

In a push architecture, the data source sends (or "pushes") data to the destination. The destination has an endpoint that continuously accepts data from the source without explicitly requesting new data. This pattern is driven by the data producer, who starts transferring data as soon as new data is available (or at a predefined interval).

Systems may opt to use push architectures when real-time data streaming is important, or event-driven notifications or alerts need to be sent out immediately. Push architectures ensure data is delivered as soon as it becomes available, which minimizes latency for the receiver. This pattern typically requires less traffic as the receiver does not need to constantly poll for new data from the source.

Managing push architectures between systems does have some drawbacks, which may lead architects to use a pull architecture. Data streaming systems may use different data formats (JSON, Apache Avro, CSV) with different data types that include strings, numbers, dates, and binary types. Not all SIEM systems will have integrations supporting every data streaming service. Receivers can also run into performance issues if data is produced too quickly or in too large volumes, overloading the destination.

Pull Architecture

In a pull (also known as polling) architecture, the destination (or "subscriber") periodically requests data from the source. This pattern removes the responsibility for initiating data transfer to the consumer of the data rather than the producer.

Systems that do not need data to be delivered in real-time can use the pull pattern to simplify data delivery. Data receivers can control the timing and volume of the data they are processing on their side of

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

the exchange, which reduces the risk of failures. The subscriber is responsible for configuring the systems that read and parse the data from the sender, which is often easier to implement and manage. The downside of the pull pattern is that there can be a delay between the availability of new data and its retrieval by the consumer. The delay will vary based on the systems involved but is normally on the order of minutes to hours compared to the push pattern's milliseconds to seconds.

References:

- Azure Event Grid: Introduction to pull delivery: https://sec549.com/id578
- Splunk Documentation: AWS Pull Architecture: https://sec549.com/id577
- AWS: What Is Amazon Data Firehose: https://sec549.com/id579
- AWS: Streaming Data Explained: https://sec549.com/id580

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Public Cloud Provider Data Transfer Services

Provider	Services	Description
AWS	Kinesis	Serverless real-time or batch data processing that supports both push and pull data transfer
	Simple Queue Service (SQS)	Messaging for event-driven systems and polling using a pull pattern
Azure	Azure Event Hub	Serverless real-time or batch processing data streaming service
	Azure Storage Account	Receivers pull blobs from storage accounts on an interval
Google Cloud	Dataflow	Serverless data streaming pipelines that can perform ETL and enrich data in a push pattern
	Pub/Sub	Pub/Sub topics make data available for a subscriber to push or pull the data

The public cloud providers offer unique services for supporting push and pull architecture patterns:

AWS
Amazon Kinesis uses both Data Firehose and Data Streams in data export and aggregation patterns. Both types have their unique characteristics, where one is more suited to push and another to pull patterns of data ingestion.

SQS Queues are also used in a data export pipeline in combination with S3 buckets, where the SQS queue is polled for notification of when a new audit log file is available for download.

Azure
Azure's Event Hub can receive and process millions of events per second, making it an ideal solution for collecting, storing, and analyzing large volumes of data in real-time. Event Hub can process data by filtering, aggregating, or analyzing data to identify patterns, anomalies, or insights. Then, the results can be directed to various destinations for further analysis, visualization, or storage. Destinations typically include SIEM collectors, databases, data warehouses, notification systems, or dashboards. Consumers receive data using Event Hub and the Advanced Message Queuing Protocol (AMQP). Events are delivered through the established session as they become available, and the client does not poll for data on an interval.

Azure Storage Accounts are used in pull-based architectures to receive log data from Azure. Log sources such as Activity logs, Entra ID logs, NSG Flow Logs, Diagnostics, and Application Insights can be written directly to a centralized storage account. These logs can be pulled by the receiver on a given frequency. More advanced configurations can use an Azure Blob Trigger to invoke an Azure Function that notifies the receive when data is available.

Google Cloud
Google Cloud's Dataflow service provides a managed streaming and batch data processing pipeline for

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

receivers to ingest data in real-time. Dataflow is built on Apache Beam, which allows customers to write a pipeline definition using Apache Beam SDK in a programming language, such as Java, Python, or Go. The data pipeline performs any necessary data transformation or enrichment before pushing the output to a log sink, which could be a BigQuery dataset, GCS bucket, or a SIEM's HTTP Event Collector (HEC).

Google's pull-based architecture uses the Pub/Sub service, which would include a topic collecting logs from the Google Cloud Logging service. Each Pub/Sub topic can have one to many subscribers, which read data from the topic. The log receiver can poll the subscription for unread messages on an interval and read messages into the SIEM.

References:

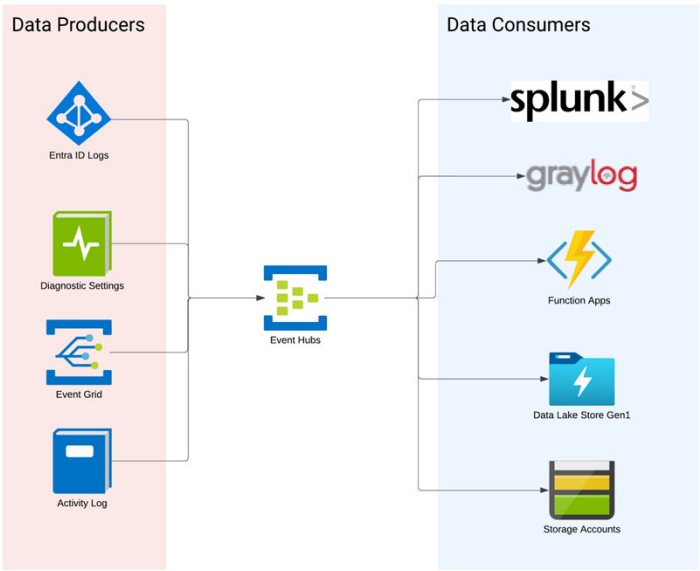
- AWS: What Is Amazon Data Firehose: https://sec549.com/id579
- AWS: Streaming Data Explained: https://sec549.com/id580
- Azure Event Hub Data Streaming: https://sec549.com/id582
- Splunking Azure: Event Hubs: https://sec549.com/id583
- Getting Microsoft Azure Data into Splunk: https://sec549.com/id587
- Streaming logs from Google Cloud to Splunk: https://sec549.com/id581

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Azure: Event Hub Log Export Pattern



- **Data Producers** inside the root management group send events and log data to the **Azure Event Hub**.
- **Data Consumers** subscribed to the Event Hub **receive** data over the Advanced Message Queuing Protocol (AMQP).

Azure's push architecture using Azure Event Hub provides real-time data streaming and event ingestion. Azure Event Hub resources perform event ingestion for many different sources and are capable of receiving and processing millions of events per second. The diagram above shows how this pattern works:

Components

- Azure Event Hub: The Event Hub resource is the central event ingestion point handling streams of data produced by the logging sources in the subscription (Entra ID audit logs, Azure Activity Logs, Resource diagnostics, and any other Event Grid sources)
- Data Producer: The event source generating data can push data to the Event Hub using either HTTP or the Advanced Message Queuing Protocol (AMQP).
- Data Consumer: Process or analyze the data stream coming from an Event Hub.

Workflow

1. Data Producers: Data sources, such as Entra ID audit logs, Azure activity logs, resource diagnostics, websites, and IoT devices, or logs, generate events that are pushed to an Event Hub resource. Each event is a small piece of data, similar to a message, which can contain both the data payload and metadata.
2. Event Ingestion: Azure Event Hubs receives events from multiple sources for processing. The Event Hub service is a scalable entry point for data capable of handling millions of events per second. Event Hub's events (i.e., messages) are temporarily stored in partitions, which are ordered sequences of events. Each data producer sends events to a namespace and partition, which are later read by data consumers.
3. Data Consumer: Consumers are applications or services processing the data streams. Each consumer connects to the Event Hub, subscribes to the event stream, and starts processing the events in a partition. Technically, consumers are "pulling" events from the Event Hub, but from an architectural perspective, this setup is considered a push architecture because data is continuously pushed from the source and made available to consumers in near real-time. The consumer is not polling for new data on a specific interval.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

The Azure Event Hub push architecture is best applied when multiple data consumers need to independently read and process the same data stream. Each consumer has isolated checkpointing and replay capabilities that allow them to manage their own reading position within the stream. From an incident response perspective, this pattern enables real-time analytics and anomaly detection.

Reference:

- Stream Azure monitoring data to an event hub and external partners: https://sec549.com/id592

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

SANS | CLOUD SECURITY

Lab 5.3

SAR: Exporting Telemetry to a SIEM – Azure

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Lab 5.3: Summary

In this lab, you:

- Reviewed the Delos centralized cross-cloud SIEM architecture
- Learned how the Sentinel Entra ID and Azure Activity Log connectors ingest logs
- Signed into the Delos Entra ID tenant to query the Azure activity logs table
- Identified which service principal has the most API activity

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

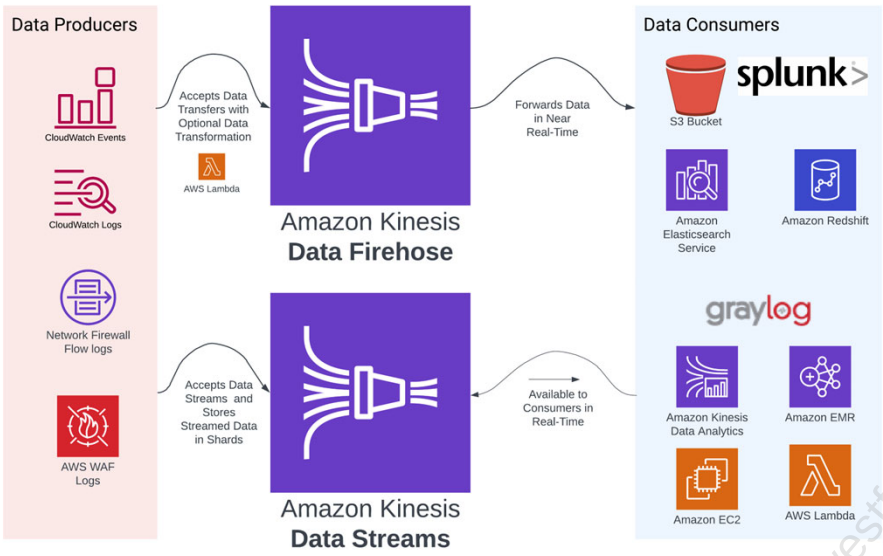
This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

AWS: Kinesis Log Export Pattern



- **Kinesis Firehose** uses a push pattern to stream from data producers to data consumers in near real time.
- **Kinesis Data Streams** stores and shards data and makes available to consumers using a pull pattern.

AWS Kinesis can be used as an aggregation point for disparate sources of data across AWS and as a mechanism to move data out of AWS and into an on-premises SIEM (security information and event management) system.

Collection and Aggregation
Kinesis provides a simple way to collect, process, and analyze large volumes of streaming data in real-time. With Kinesis, you can capture data from various sources, such as Amazon CloudWatch Logs, Amazon VPC Flow Logs, AWS IoT, and third-party applications, and combine them into a single stream for processing and analysis.

Export
To move data out of AWS and into an on-premises SIEM system, you can use Kinesis Data Firehose to load streaming data into various destinations, including on-premises storage systems. Kinesis Data Firehose can buffer, compress, and encrypt data before sending it to the destination, and it can also transform data into the required format.

If a push pattern is required for data export, consider Kinesis Data Streams. Data Streams may serve as a sharded, encrypted data collection point for your applications. You can then use the Kinesis Data Streams APIs or SDKs to publish data to the stream or use the Kinesis Data Streams client libraries to consume data from the stream.

AWS Kinesis Data Firehose
The primary service initially offered was called Data Firehose. So as when individuals mention Kinesis, they are typically referring to Kinesis Data Firehose. This service functions as a straightforward data transfer tool. Incoming data is streamed into a Firehose resource and then pushed to a destination, which could either be another AWS service or an external location. The data transfer process is nearly real-time, and some limited transformation capabilities can be configured. For more intricate transformations, customized lambda functions can be written and configured as destinations.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

AWS Kinesis Data Streams

In the case of Data Streams, data producers enter the records into Kinesis data streams or KDS just as with Data Firehose. With Data Streams however, data is retained, indexed, sharded, and made available for data consumers to pull records in a performant manner.

Essentially, Data Firehose is primarily a data transfer service, while Data Streams is designed for situations where high-throughput, low-latency data streaming capabilities are required or where data cannot be pushed to the consumer but must be pulled.

Kinesis Data Streams enable consumers to scale their data processing according to their needs by allowing them to:

- Specify the number of records they want to read per request.
- Specify the maximum amount of data they want to read in a single request.

Additionally, Kinesis Data Streams supports multiple consumers reading from the same stream concurrently, allowing for flexible and scalable architectures.

Graylog is an example of logging infrastructure that cannot accept streams from a Kinesis Firehose as inbound, since push patterns are not supported by default. Therefore, utilizing Kinesis Data Streams offers more flexibility in your data pipeline, as it provides an open-ended model for consumers with support for multiple consumers and destinations. By using Kinesis Data Streams, you can easily adapt your logging infrastructure to handle large volumes of data while enabling seamless consumption by multiple downstream systems.

References:

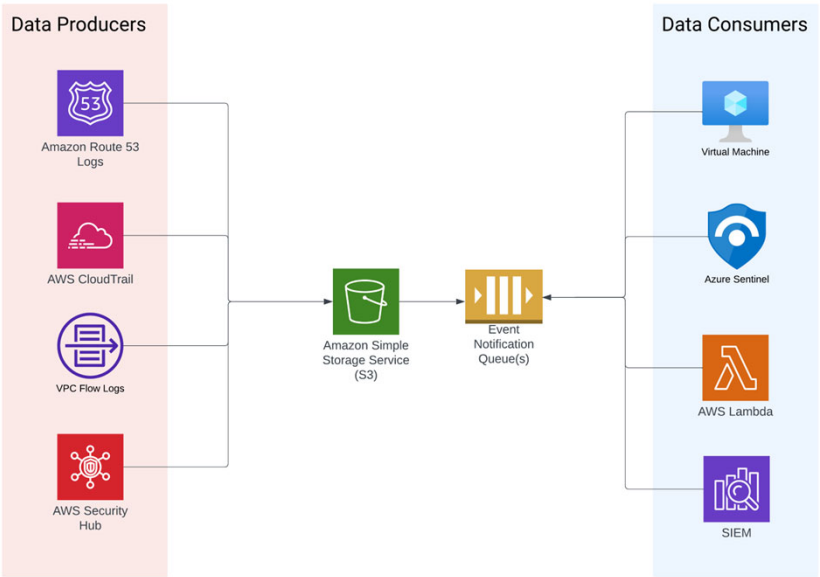
- Getting started with Amazon Kinesis Data Streams: https://sec549.com/id353
- AWS Kinesis CloudWatch Input: https://sec549.com/id354
- Configure Amazon Kinesis Firehose to send data to the Splunk platform: https://sec549.com/id584
- Configure Kinesis inputs for the Splunk Add-on for AWS: https://sec549.com/id355
- Greylog: AWS Kinesis/CloudWatch Input: https://sec549.com/id585

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

AWS: S3 and SQS Log Export Pattern



- **Data Producers** write log data into a central S3 bucket with event notifications sending messages to an SQS queue.
- **Data Consumers** poll the queue(s) for new messages and then pull the new log objects from the S3 bucket.

The pull log architecture pattern using Amazon Simple Storage Service (S3) and Amazon Simple Queue Service (SQS) queues is useful for scenarios where large volumes of data need to be processed by different consumers at their own pace. The diagram above shows how this pattern works:

Components

- Amazon S3 Bucket: The S3 service is used to store incoming data that needs to be processed from sources, including AWS CloudTrail, VPC Flow Logs, AWS Security Hub, Route53 DNS Logs, etc.
- Amazon SQS: The SQS service is a fully managed message queuing service that helps decouple and scale microservices, distributed systems, and serverless applications. The SQS queue(s) are used to notify receivers about new data available for processing.

Workflow

1. Data Producers: Data is generated by various sources (AWS CloudTrail, VPC Flow Logs, AWS Security Hub, Route53 DNS Logs) and stored in the S3 bucket using a dedicated prefix (/CloudTrail, /VPCFlow, /SecurityHub /Route53).
2. S3 Event Notifications: For each new object uploaded to S3, a notification is generated and sent to a dedicated queue for each prefix (CloudTrail, VPCFlow, SecurityHub Route53). The notification message in the queue does not contain the actual data, but metadata about the new object, including the S3 bucket name and object key (path to the file). The notification message will sit in the SQS queue until the receiver reads the message. This decouples the data production from its consumption, allowing consumers to process the data at their own pace.
3. Data Consumers: The data consumers poll the SQS queue(s) on an interval to receive messages about new log data available in S3. After reading an SQS message, the consumer uses the object metadata in the message to pull the corresponding data file from the S3 bucket. After successfully processing the log file, the consumer can then delete the message from the SQS queue to acknowledge its processing. If the message is not deleted, SQS will make it visible again after the visibility timeout, allowing the consumer or retry mechanism to process it.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

The S3/SQS pull architecture is well-suited for scenarios like log analysis, data warehousing, real-time analytics, and any other use case where large sets of data need to be reliably processed by consumers that do not support push architectures with real-time streaming.

References:

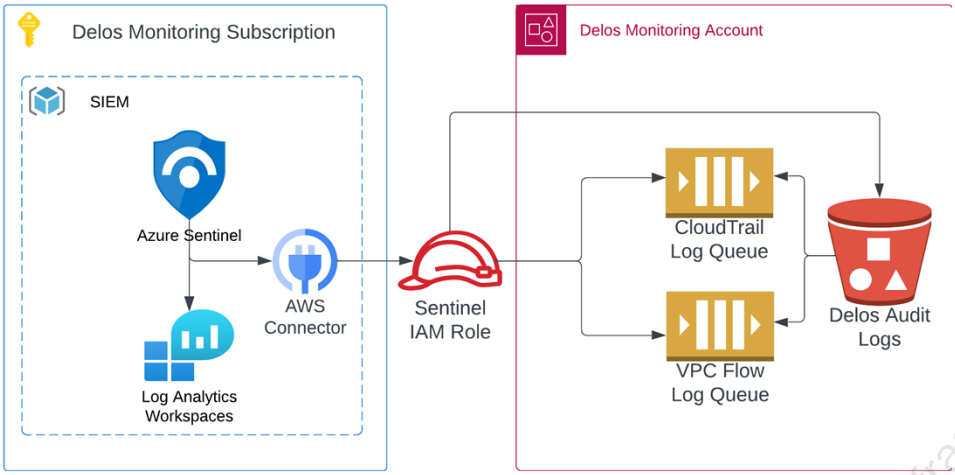
- AWS Getting started with Amazon SQS: https://sec549.com/id590
- Amazon S3 Event Notifications: https://sec549.com/id591

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Microsoft Sentinel: Ingesting AWS Logs with SQS and S3



- **AWS** monitoring account resources:
  - Create a queue for each log type
  - Configure an S3 event notification per log type prefix
  - Create an IAM Role that trusts the Sentinel tenant and workspace id
- **Sentinel** workspace resources:
  - Data connector for each log type assumes the IAM role and checks the queue
  - Pulls new objects from the audit log bucket into the Sentinel workspace

Microsoft Sentinel's Content Hub hosts the AWS S3 data connector, capable of receiving data from AWS environments. Microsoft's design uses the Simple Queue Service (SQS) and Simple Storage Service (S3) log export pattern to pull data from AWS.

Customers are responsible for hosting the following resources in their monitoring account for Sentinel to read audit log data from the organization's centralized S3 bucket:

- SQS Queues: Start by creating a dedicated queue for each data source (CloudTrail, VPC Flow Logs, GuardDuty, SecurityHub, etc.) inside the bucket. As new objects are written into the data source's unique prefix, an event notification message will be sent to the queue.
- S3 Event Notification: For each data source's prefix in the bucket, all new objects will send a message to the queue. This ensures that each queue has all of the messages that have not yet been processed by the Sentinel workspace. Event notification messages in the queue do not actually contain the object data, only the metadata
- IAM Role: Microsoft's Sentinel service will need to assume an IAM Role in your AWS account to read and delete messages from the queues as well as get objects from the audit logs bucket. For Sentinel to assume the role, a special trust policy is required for Microsoft Sentinel's tenant (sts.windows.net/cab8a31a-1906-4287-a0d8-4eef66b95f6e/) to assume the role. The trust policy (shown next) must allow Sentinel's tenant to assume the role. Additionally, the external ID value must match your Sentinel workspace's unique ID (UUID) to prevent the confused deputy vulnerability.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Example Sentinel IAM Role trust policy:

```
{
 "Version": "2012-10-17",
 "Statement": [
   {
    "Effect": "Allow",
    "Principal": {
     "Federated": "arn:aws:iam::YOUR_AWS_ACCOUNT_ID:oidc-provider/sts.windows.net/
                   cab8a31a-1906-4287-a0d8-4eef66b95f6e/"
    },
    "Action": "sts:AssumeRoleWithWebIdentity",
    "Condition": {
     "StringEquals": {
      "sts.windows.net/cab8a31a-1906-4287-a0d8-4eef66b95f6e/:aud":
       "api://d4230588-5f84-4281-a9c7-2c15194b28f7",
      "sts:RoleSessionName":
      "MicrosoftSentinel_YOUR_SENTINEL_WORKSPACE_ID"
     }
    }
   }
 ]
}
```

Reference:

- Connect Microsoft Sentinel to Amazon Web Services: https://sec549.com/id595

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

SANS | CLOUD SECURITY

Lab 5.4

SAR: Exporting Telemetry to a SIEM – AWS

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Lab 5.4: Summary

In this lab, you:

- Reviewed the log export pattern from the AWS audit logs S3 bucket into Microsoft Sentinel
- Found the AWS Sentinel IAM roles with permissions to read the audit logs SQS queue and S3 data
- Ensured the Sentinel AWS S3 connector was properly using the IAM roles to authenticate to the Delos AWS organization
- Ran a Sentinel query to identity the AWS network interface with the highest number of outbound connections

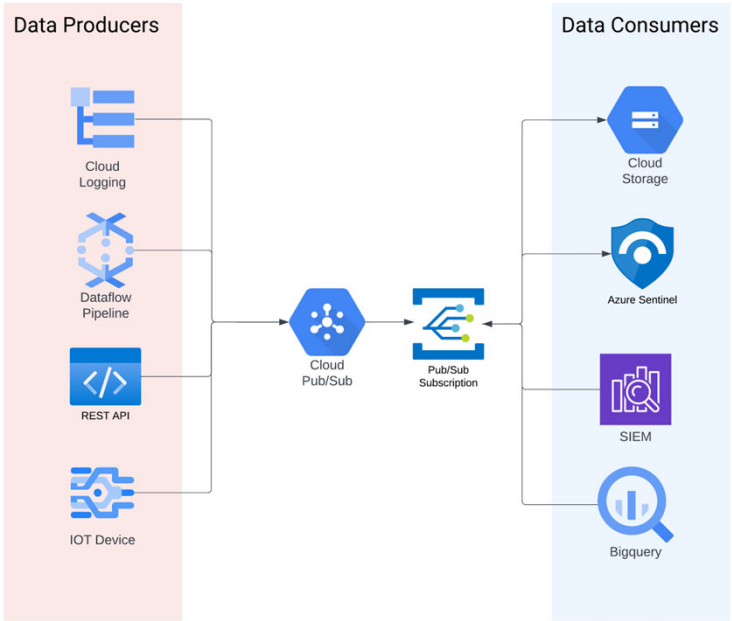
This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Google Cloud: Pub/Sub Log Export Pattern



- **Data Producers** write data into a Google Cloud Pub/Sub topic.
- **Data Consumers** subscribe to the Pub/Sub topic using either a push or a pull architecture to process messages as they become available.

Google Cloud Pub/Sub is a messaging service that allows services to produce events (publishers) and clients to process events (subscribers). Pub/Sub supports both push and pull message delivery models, making it a flexible option for event-driven architectures, real-time analytics, and data pipelines. The diagram above shows how the Google Cloud Pub/Sub architecture works:

Components

- Pub/Sub Topic: Each Pub/Sub Topic is a named resource that accepts messages from a publisher (similar to an Event Hub), which includes but is not limited to Cloud Logging, Dataflow pipelines, IoT devices, and custom applications.
- Pub/Sub Subscription: Each Pub/Sub Topic can have one to many Subscriptions. Each Subscription is responsible for making the stream of messages available for the subscribing application. Subscriptions can be configured to use either the push or pull message delivery model.

Pub/Sub Push Subscription

Pub/Sub automatically sends messages to an HTTP endpoint specified by the subscription. When a message is sent to a Topic, Pub/Sub pushes the message to all the subscriber HTTPS endpoints that are configured to receive the data.

Workflow

1. Data Producers: Services, such as Cloud Logging and Dataflow Pipelines, send messages to a Pub/Sub Topic. For example, as cloud audit logs are captured for the organization, messages, which include the data, are sent in near real-time to the topic.
2. Data Consumers: As messages are received by the Pub/Sub Topic, the service immediately pushes messages to the subscriber's HTTPS endpoint. The subscriber's HTTPS endpoint is responsible for parsing the message and processing the data.
3. Message Handling: The subscriber's endpoint sends an acknowledgment message back to the Pub/Sub subscription after processing the message. If the subscriber's endpoint does not acknowledge the message within the acknowledgment deadline, Pub/Sub will retry sending the message.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

The Pub/Sub push pattern is ideal for scenarios where you want to minimize the latency between when messages are published and when they are processed.

Pub/Sub Pull Subscription
Pub/Sub stores messages in the subscription and waits for the data consumer to explicitly request messages. The Pub/Sub pull pattern allows data consumers to control the message processing rate and process messages in batches.

Workflow
1. Data Producers: Services, such as Cloud Logging and Dataflow Pipelines, send messages to a Pub/Sub Topic. For example, as cloud audit logs are captured for the organization, messages, which include the data, are sent in near real-time to the topic.
2. Data Consumers: Subscribers periodically send requests to Pub/Sub to pull messages from the subscription.
3. Message Handling: The subscriber sends an acknowledgment for each message to Pub/Sub, which tells the subscription to remove the message from the queue.

The Pub/Sub pull pattern is ideal for subscribers that need to process messages at their own pace or when more complex processing is required.

Choosing Between Pub/Sub Push and Pull
Pub/Sub subscriptions may choose the push pattern for lower latency (fewer polling requests) when an external endpoint can immediately process messages. However, this requires the data consumer to manage the external endpoint and automatically scale as the message volume increases or decreases.

The Pub/Sub pull pattern is often used when an external message processing endpoint is not available. Rather than exposing an endpoint to the Internet, data consumers may choose to pull messages needing only an egress connection to the Pub/Sub service. The pull pattern provides more control over message processing rate and the ability to process messages in batches.

References:

- Google Cloud Pub/Sub Architectural Overview: https://sec549.com/id593
- Google Cloud Pub/Sub Push Subscriptions: https://sec549.com/id594

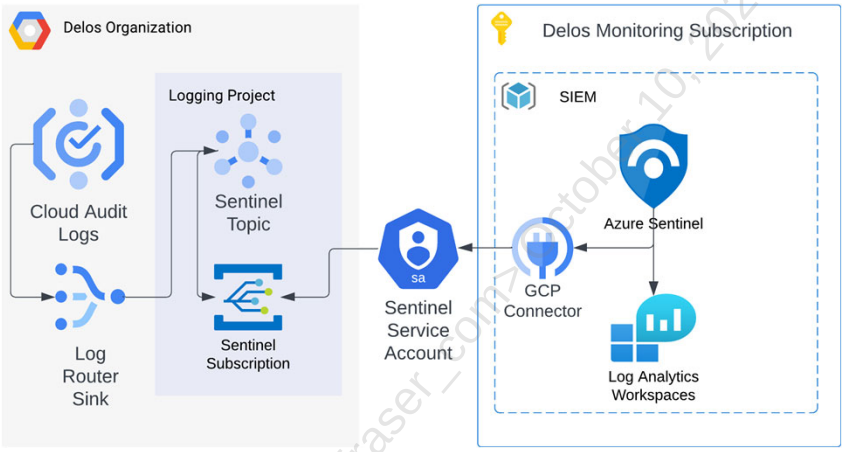
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Microsoft Sentinel: Ingesting Google Cloud Logs

- **Google Cloud** monitoring project account resources:
  - Create a cloud logging sink for audit logs to stream to a Pub/Sub topic
  - Create a Pub/Sub pull subscription for the Sentinel workspace
  - Create a service account that trusts the Sentinel tenant and workspace with permission to get subscription messages
- **Sentinel** workspace resources:
  - Data connector for cloud audit logs impersonates the service account
  - Reads messages from the Pub/Sub topic's subscription



Microsoft Sentinel's Content Hub hosts the GCP Pub/Sub Audit Logs data connector, capable of receiving data from Google Cloud audit logs. Microsoft's design uses the Pub/Sub log export pattern with a pull subscription to pull audit log data from GCP.

Customers are responsible for hosting the following resources in their monitoring project for Sentinel to read audit log data from the organization's audit log buckets:

- Pub/Sub Topic: The GCP Pub/Sub Audit Logs data connector consumes GCP data from the Pub/Sub service. Start by creating a Pub/Sub topic that will receive data from the organization's audit logging service.
- Log Router Sink: Google Cloud Logging uses Log Router Sink(s) to stream log data into GCS buckets, BigQuery datasets, Pub/Sub Topics, and even directly to Splunk. To route data to the Sentinel Pub/Sub Topic, create a new log sink that forwards all audit log events to the topic we just created.
- Pub/Sub Subscription: Next, create a new subscription for the Sentinel Pub/Sub Topic. Sentinel uses the pull pattern to read data from the subscription.
- Workload Identity Pool: Sentinel uses OIDC to impersonate the service account inside the GCP logging project. Luckily, you learned about this capability in an earlier section. The workload identity pool ID must be set to your Sentinel workspace unique identifier (UUID) with the dashes removed. Then, add an OIDC provider to the workload identity pool that trusts Sentinel's Entra ID tenant ID (33e01921-4d64-4f8c-a055-5bdaffd5e33d).
- Service Account: Create a service account that allows impersonation from the Sentinel workload identity pool. This service account needs the pubsub.subscriptions.get and pubsub.subscriptions.consume permissions on the Pub/Sub subscription.

Unfortunately, the Sentinel GCP Pub/Sub Audit Logs data connector does not support the identity bastion pattern discussed earlier in the course (as of this writing). The Sentinel Service Account must live in the same project as the Sentinel Pub/Sub Topic and Subscription. This is yet another example of a cloud provider's implementation forcing cloud architects to make an exception to the desired pattern.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Reference:

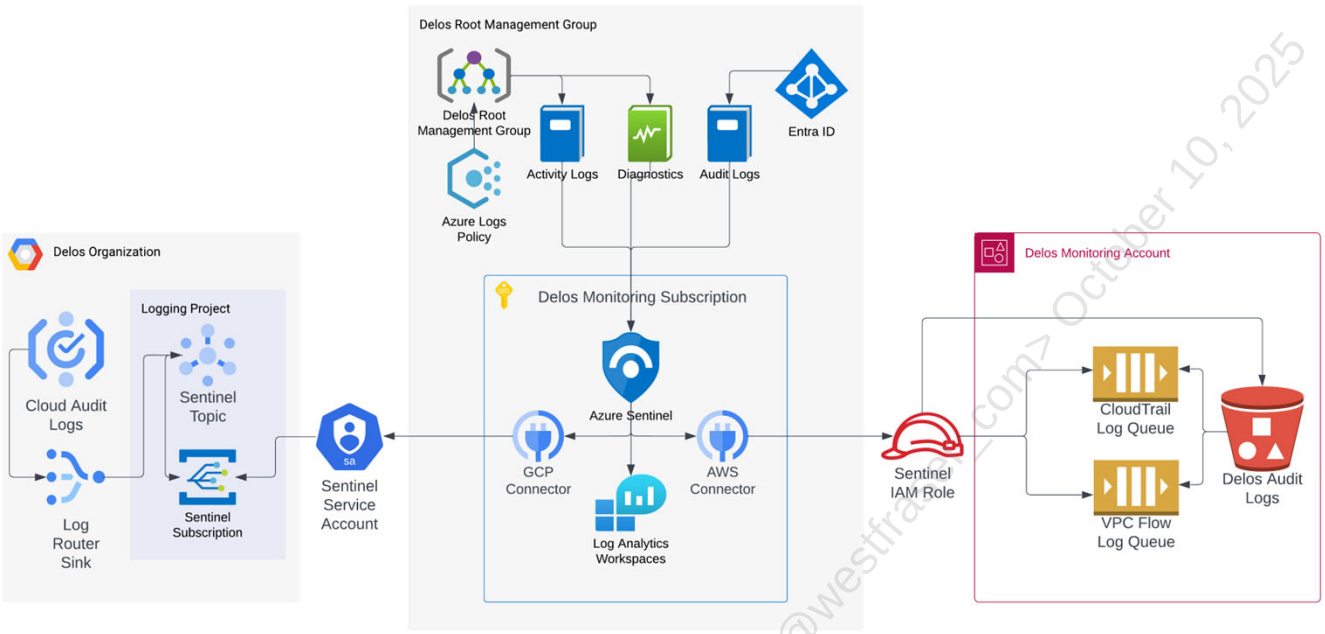
- Ingest Google Cloud Platform log data into Microsoft Sentinel: https://sec549.com/id596

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Microsoft Sentinel Centralized SIEM Architecture



The diagram shows the new Delos centralized SIEM architecture consuming audit logs from AWS, Azure, and Google Cloud using Microsoft Sentinel. It is important to realize that many alternate data export patterns, data processing and enrichment services, and SIEM products could achieve the same end result. It is important to include the business, finance, and security teams in these decisions, as the underlying technologies may influence this centralized audit logging architecture.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

SANS | CLOUD SECURITY

Lab 5.5

SAR: Exporting Telemetry to a SIEM – GCP

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Lab 5.5: Summary

In this lab, you:

- Reviewed the log export pattern from the Google Cloud audit logs storage bucket into Microsoft Sentinel
- Found the Google Cloud service account with permissions to read the audit log data from the Pub/Sub topic
- Ensured the Sentinel Google Pub/Sub Audit Logs connector was properly using the service account for authentication to the logging project
- Ran a Sentinel query to identity the Google Cloud service account reading the most data from the Robotics BigQuery data set

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Course Roadmap

Section 1: Cloud Account Management and Identity Foundations

Section 2: Implementing an Identity Perimeter in the Cloud

Section 3: Network Access Perimeters for the Cloud

Section 4: Data Access Perimeters in the Cloud

Section 5: Enabling the Cloud-Focused SOC

- Incident Response in the Cloud
  - Lab 5.1: Threat Model: Managing Cloud-Native Events
- Intra-Cloud Logging and Aggregation
  - Lab 5.2: SAR: Centralizing Cloud-Native Events
- Centralization and Export Patterns
  - Lab 5.3 SAR: Exporting Telemetry to a SIEM – Azure
  - Lab 5.4 SAR: Exporting Telemetry to a SIEM – AWS
  - Lab 5.5 SAR: Exporting Telemetry to a SIEM – GCP
- Course Wrap-Up
  - Lab 5.6: CloudWars: Incident Response and Final Presentation
- Additional Resources

This area is intentionally left blank.

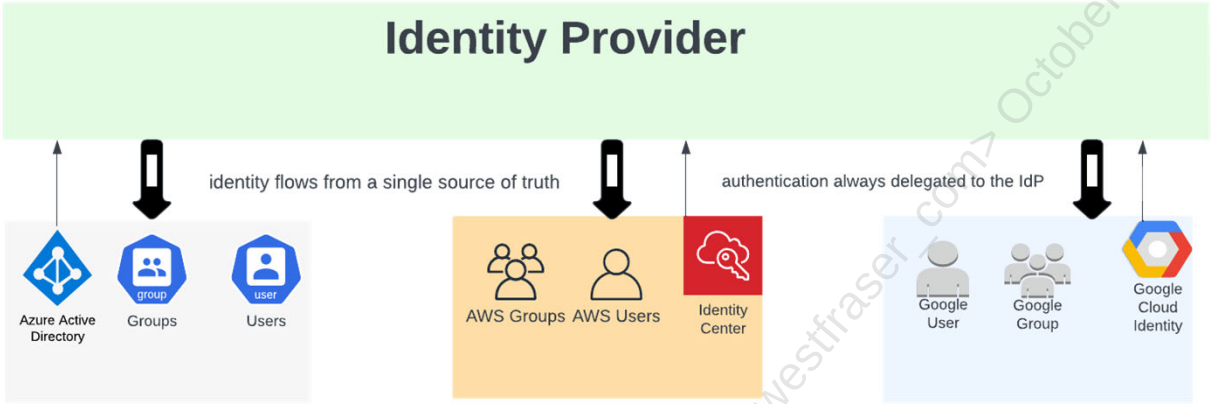
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Section 1: Cloud Account Management and Identity Foundations

- Single sign-on (SSO) and centralized identity providers
- Cloud organizational hierarchy and policy guardrails
- Privileged identity management and cloud administrator job roles



In the first section, you learned the unique aspects of security architecture in the cloud, emphasizing simplicity, least privilege, open design, and with rational defaults set to fail closed. We covered threat modeling as a tool to understand and mitigate risk. It is a team effort involving a diverse group of stakeholders who collectively model the system and data flow in order to document and identify risks. You learned that cloud security is based on securing through policy and that identity, in particular, becomes an increasing important perimeter in the cloud.

Starting with federated access methods from your centralized identity provider, this course then covered the higher-level resources in the cloud and how permissions represent an ownership structure from parent to child. We discussed policy inheritance and how it goes down the hierarchy but never up the hierarchy, as well as how your hierarchy design should be driven by IAM inheritance and the need for clear resource ownership. Wrapping up Section 1, we covered different options for break-glass scenarios and how to manage permissions for various job roles, including the root user/global administrator.

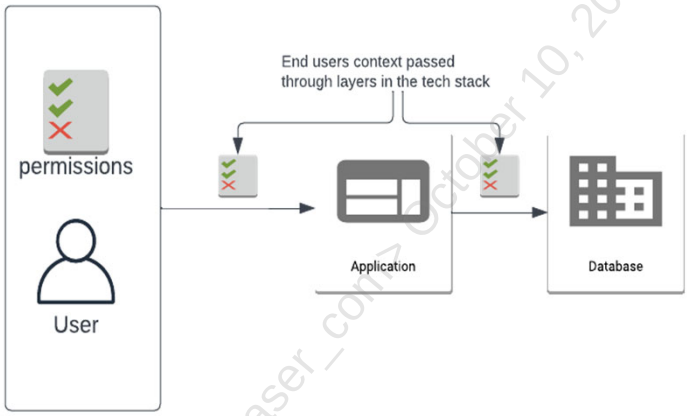
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Section 2: Implementing an Identity Perimeter in the Cloud

- Zero Trust patterns and the need to maintain user context throughout authorization
- Conditional access to cloud resources
- Customer Identity and Access Management (CIAM) and end-user identity federation
- Cross-cloud machine identity federation



Section 2 kicked off by covering the drivers for cloud migration, including reduced costs, scalability, enhanced security, and increased flexibility, along with a review of the 5 Rs that are the strategies for cloud migrations: Rehost, Refactor, Revise, Rebuild, and Replace. Central to this section were the concepts behind the Zero Trust movement. You learned that ZT principals can be used to enhance security by adding granular, layer 7 controls to create micro-perimeters around the most vulnerable assets. Building on our understanding of Zero Trust in the cloud, we took a deep-dive look at Cognito and how it can be used to uplift legacy authorization schemes at the application layer.

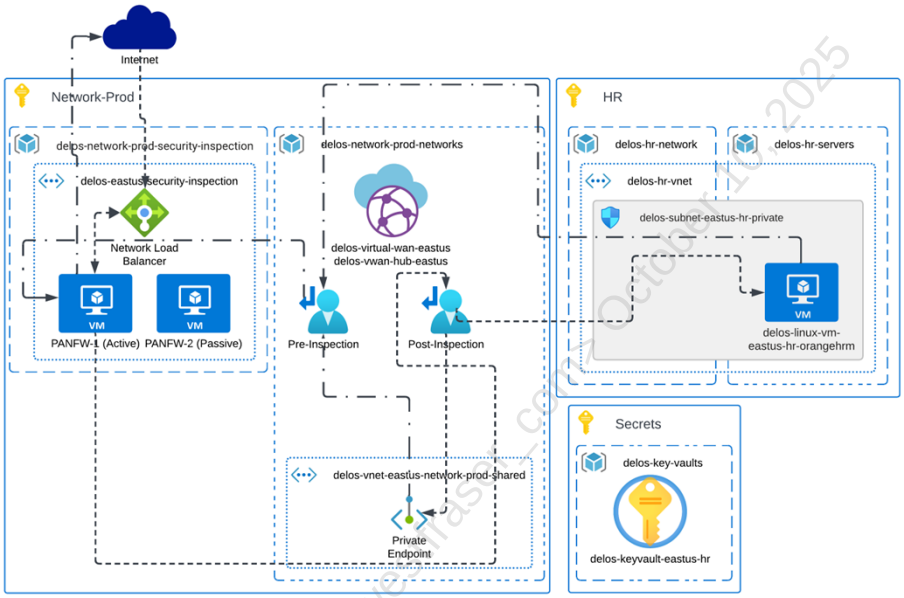
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Section 3: Network Access Perimeters in the Cloud

- Managing network resources using Shared VPC
- Building micro-segmentation by default with hub and spoke
- Centralizing traffic inspection with cloud-hosted firewalls
- Hosting shared services using a private link



Section 3 built the foundation for Zero Trust network perimeters. After learning the differences between on-premises and cloud network security controls, the Delos International Management organization started migrating all network resources into a centrally managed network host account. With full control of those resources, the network infrastructure team was then able to break up each system into a dedicated micro-network. Using a hub-and-spoke network architecture, the network team created central networks for ingress, egress, and traffic inspection. Leveraging the central inspection network, the security team established micro-segmentation using firewall policies to restrict north-south and east-west traffic flow. Finally, the network team built a shared services network for accessing resources from any network in the hub-and-spoke architecture.

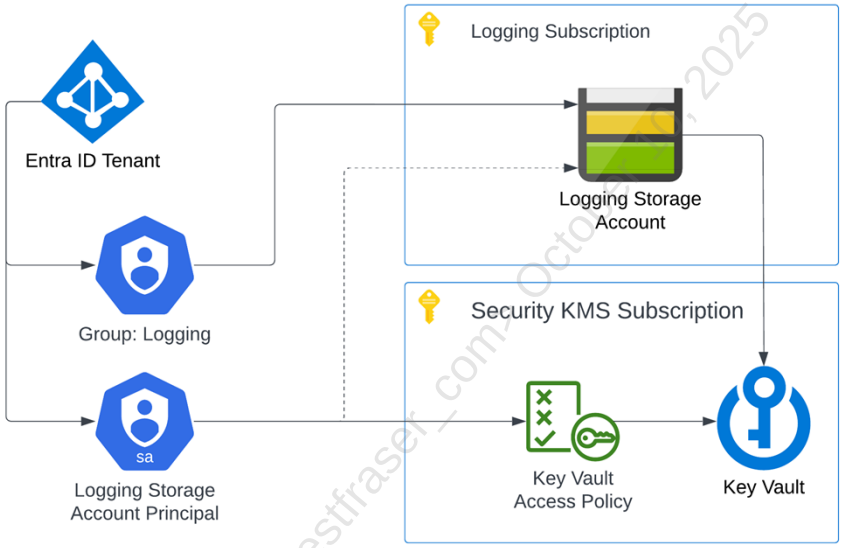
Licensed To: Olaitan Matthew Odetola matthew_odetola@westfraser_com October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Section 4: Data Access Perimeters in the Cloud

- Data security and privacy playbook
- Data discovery and classification
- Defending data in the cloud
- Data Lake security designs
- Key management architecture
- Business continuity and disaster recovery



Section 4 built data perimeters into the Delos International Management organization by focusing on defining, dissecting, and defending data stored in the cloud. Cloud-native controls allowed the security team to properly define data using data classification tagging and data loss prevention scanning. After building the data classification inventory, key cloud-native security controls were used to dissect and defend data. Data lake security design helped identify techniques for granting least privilege access to data stored in AWS S3 and Google BigQuery services. Finally, data encryption, centralized key management architecture patterns, and disaster recovery designs were used to protect data at scale.

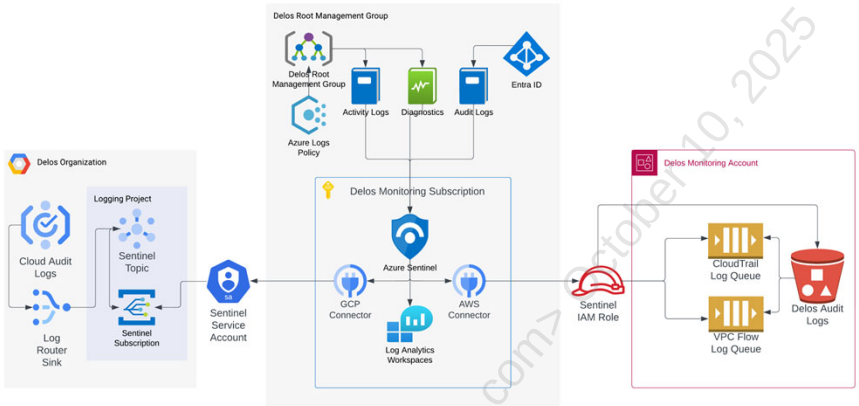
Licensed To: Olaitan Matthew Odetola matthew_odetola@westfraser_com October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Section 5: Enabling the Cloud-Focused SOC

- Cloud incident response processes
- Intra-cloud logging and aggregation
- Centralized logging and export patterns
- CloudWars final presentation



In this section, we focused on the security architect's role in enabling the security operations center (SOC) so they are best positioned to investigate incidents and log events as well as to hunt for threats in the new cloud-based world. Covered in this section is a deep dive on cloud data sources as well as aggregating logs and cloud-native events within the CSP while positioning them for export to the central SIEM. To that end, we deep-dived into audit log sources and both push and pull patterns into either a class data warehouse or a more modern security data lake. Finally, students wrapped up the course by finishing their CloudWars capstone exercise and presenting that to their peers.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

SANS | CLOUD SECURITY

Lab 5.6

CloudWars: Incident Response and Final Presentation

Refer to the lab workbook for instructions.

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Course Roadmap

Section 1: Cloud Account Management and Identity Foundations

Section 2: Implementing an Identity Perimeter in the Cloud

Section 3: Network Access Perimeters for the Cloud

Section 4: Data Access Perimeters in the Cloud

Section 5: Enabling the Cloud-Focused SOC

- Incident Response in the Cloud
  - Lab 5.1: Threat Model: Managing Cloud-Native Events
- Intra-Cloud Logging and Aggregation
  - Lab 5.2: SAR: Centralizing Cloud-Native Events
- Centralization and Export Patterns
  - Lab 5.3 SAR: Exporting Telemetry to a SIEM – Azure
  - Lab 5.4 SAR: Exporting Telemetry to a SIEM – AWS
  - Lab 5.5 SAR: Exporting Telemetry to a SIEM – GCP
- Course Wrap-Up
  - Lab 5.6: CloudWars: Incident Response and Final Presentation
- Additional Resources

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cloud Security

- SANS Cloud Security
  - sans.org/cloud
  - sans.org/cloudace
  - sansurl.com/cloud-discord
  - SANS CloudSecNext Summit
  - SANS Cloud Security Exchange
- cloudsecuritypodcast.tv
- fwdcloudsec.org Conference
- cloudseclist.com
- rhinosecuritylabs.com/blog

References:

- SANS Cloud Security:
  - https://sans.org/cloud-security
  - https://www.sans.org/cloudace
  - https://sansurl.com/cloud-discord
- Cloud Security Podcast: https://www.cloudsecuritypodcast.tv/
- fwd:cloudsec Conference: https://fwdcloudsec.org
- CloudSecList Newsletter: https://cloudseclist.com/
- Rhino Security Blog: https://rhinosecuritylabs.com/blog/

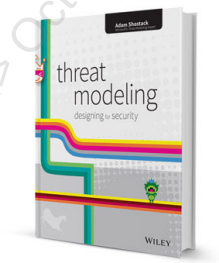
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Threat Modeling Resources

- Elevation of Privilege Game[1]
  - A threat modeling card game built in 2010 by Adam Shostack
- *Threat Modeling: Designing for Security*[2]
  - How to use threat modeling in the SDLC and design process: Adam Shostack
- "Threat Modeling Gamification for Fun, Profit, and World Domination"[3] Vlad Styran
- OWASP Threat Dragon[4]
  - A self hosted free tool for threat modeling



1. https://sec549.com/id431
2. https://sec549.com/id432
3. https://sec549.com/id433
4. https://sec549.com/id434

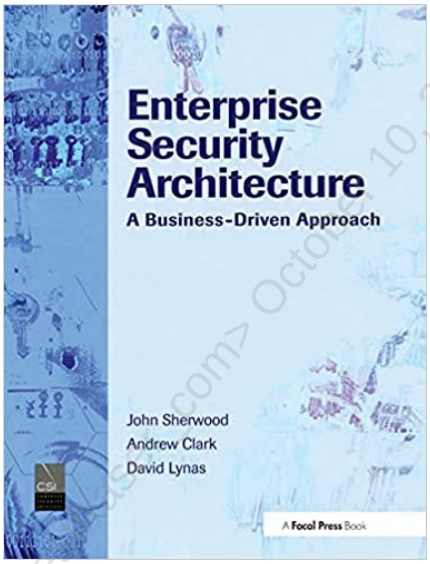
Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

"The Big Blue Book"

- From the SABSA Institute: *Enterprise Security Architecture: A Business Drive Approach*
  - By John Sherwood, Andrew Clark, David Lynas



Book description from SABSA:[1]

"Security is too important to be left in the hands of just one department or employee—it's a concern of an entire enterprise. **Enterprise Security Architecture** shows that having a comprehensive plan requires more than the purchase of security software—it requires a framework for developing and maintaining a system that is proactive. The book is based around the SABSA layered framework. It provides a structured approach to the steps and processes involved in developing security architectures. It also considers how some of the major business issues likely to be encountered can be resolved."

1. https://sec549.com/id430

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

Cloud Security Training Environments

- CloudGoat
  - https://github.com/RhinoSecurityLabs/cloudgoat
- TerraGoat
  - https://github.com/bridgecrewio/terragoat
- ServerlessGoat
  - https://github.com/OWASP/Serverless-Goat
- flAWS 2
  - http://flaws2.cloud/
- Sadcloud
  - https://github.com/nccgroup/sadcloud

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

This area is intentionally left blank.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

© SANS Institute 2025

SANS | CLOUD SECURITY

General inquiries: info@sans.org
Registration: registration@sans.org
Tuition: tuition@sans.org
Press: press@sans.org
310-654-SANS (7267)

Contacts and Resources

AUTHOR
Eric Johnson
ejohnson@sans.org

AUTHOR
David Hazar
david@hazardsec.com

AUTHOR
Gregory Leonard
gleonard@sans.org

CLOUD RESOURCES
sans.org/cloud-security
@sanscloudsec

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025

Eric Johnson
Eric Johnson is a co-founder and Principal Security Engineer at Puma Security and a Senior Instructor with the SANS Institute. His experience includes cloud security assessments, cloud infrastructure automation, static source code analysis, web and mobile application penetration testing, secure development lifecycle consulting, and secure code review assessments. Eric is the lead author and an instructor for SEC540: Cloud Security and DevSecOps Automation and a co-author and instructor for both SEC549: Cloud Security Architecture and SEC510: Cloud Security Controls and Mitigations. Additionally, Eric is a SANS Security Awareness Developer Training Advisory Board Member and SANS Analyst for Application Security and DevSecOps Surveys.

David Hazar
David Hazar is a security consultant based in Salt Lake City, Utah, focused on vulnerability management, application security, cloud security, and DevOps. David has 20+ years of broad, deep technical experience gained from a wide variety of IT functions held throughout his career, including Developer, Server Admin, Network Admin, Domain Admin, Telephony Admin, Database Admin/Developer, Security Engineer, Risk Manager, and AppSec Engineer. David is a co-author and instructor for LDR516: Building and Leading Vulnerability Management Programs, an instructor for and contributor to SEC540: Cloud Security and DevSecOps Automation, and has also developed and led technical security training initiatives at many of the companies for which he has worked.

Gregory Leonard
Greg is a Senior Cloud Security Architect with Milwaukee Tool, where he works to ensure cloud security best practices are implemented for development initiatives. Greg's responsibilities over the course of his career have included application security testing, cloud security testing, application architecture and security, infrastructure design and implementation, performance diagnostics, and security research. In his time with SANS, Greg has authored application security content related to secure coding for web and mobile applications, threat awareness, and top development design flaws, as well as contributing to DevSecOps and Cloud Security content.

Licensed To: Olaitan Matthew Odetola <matthew_odetola@westfraser_com> October 10, 2025